

SYNTHETIC TEST DATA - NOT A VALID ATO

System Security Plan

Flank Speed IL5 - Microsoft 365 DoD Tenant (Synthetic)

Fixture / version: SYN-FS-IL5-001 / 2.0

Scenario date: 2026-09-24

Environment: Flank Speed-inspired Microsoft 365 DoD collaboration tenant, using the Office 365 DoD service environment as public context rather than GCC High. Exchange Online, SharePoint Online, OneDrive, and Teams are candidate in-scope service workloads; their actual tenant provisioning and authorized service boundaries have not been verified. The modeled boundary is tenant configuration and operation plus explicitly qualified candidate inherited service protections.

SYNTHETIC TEST DATA - NOT A VALID ATO

A tenant-level SSP with explicit shared responsibilities and selected control narratives. Forty controls are a representative subset, not a complete IL5/FedRAMP/CNSSI baseline or a control-effectiveness claim.

This is an original production-style test scenario. It is not an official Navy, Microsoft, DISA, eMASS or FedRAMP submission. All operational settings and findings are invented; public service descriptions do not establish this tenant's authorization or control effectiveness.

Milestone	Fixture disposition
Source documents	Generated synthetic reference material
Assessment evidence	Four fictional samples; other evidence explicitly absent
Control status	Illustrative; not assessed
Authorization	Unsigned, not effective; no inheritance verified
SPIN workflow	Receipt, analysis, review, approval and publication remain separate

SYNTHETIC TEST DATA - NOT A VALID ATO

1. Document control and authorization boundary

Mission: Notional maritime-support collaboration for 2,400 synthetic workforce accounts organized into six invented mission groups. The scenario covers messaging, meetings, controlled document collaboration, records obligations, and incident coordination. Every account, configuration, event, exception, and assessment observation in this fixture is invented. No actual Navy mission, configuration, tenant, authorization, or assessment is represented.

Tenant operator: Synthetic Maritime Collaboration Operations Office, an invented customer-side tenant operator; not Microsoft, DISA, or a real Navy organization.

Synthetic tenant identifier: SYN-FS-IL5-001 is a fixture identifier only, not a tenant GUID, subscription identifier, government system identifier, or routable service address.

Categorization assumption: Notional confidentiality Moderate, integrity Moderate, availability Moderate working categorization for an IL5-context collaboration use case. IL5 is not a FIPS 199 impact category. Mission-specific categorization, information types, privacy analysis, DoD overlays, and authorizing-official concurrence remain unresolved; no classified processing or operational CUI is included.

Baseline limitation: Forty representative NIST SP 800-53 Rev. 5 base controls, without a complete enhancement set or approved organization-defined parameters. This is not a complete IL5, FedRAMP High, CNSSI 1253, or tailored DoD baseline. Every target below is notional and requires applicability, inheritance, licensing, and authority review.

In-scope logical services

- Tenant identity and federation configuration, account lifecycle interfaces, and customer-operated authentication policy.
- Tenant privileged role assignment, separation of administrative identities, and privilege-review procedures.
- Notional customer configuration of Exchange Online DoD messaging and mailbox access.
- Notional customer configuration of SharePoint Online DoD sites and document permissions.
- Notional customer configuration of OneDrive DoD individual workspaces and departure handoffs.
- Notional customer configuration of Teams DoD membership, collaboration, and meeting policy.
- Tenant access-policy decisions that consume external device posture assertions; not endpoint platform operation.
- Tenant-accessible audit collection, source reconciliation, and investigation handoffs, subject to verified log availability.
- Customer information-protection, sharing, records-retention, and legal-hold governance, with product-dependent functions conditional.
- Tenant configuration/change governance and workload-specific continuity/recovery coordination.

Explicit exclusions

- Real Navy Flank Speed configuration, actual DoD operational data, CUI, classified information, and real identities or credentials.
- Customer devices, endpoint-management services, EDR platforms, identity-federation infrastructure outside the tenant, customer networks, and their accreditation boundaries.
- Azure subscriptions, virtual machines, IaaS firewalls, Azure Key Vault, and other arbitrary Azure resources; none is represented as a native Microsoft 365 component.
- Third-party SaaS, third-party backup, external SIEM platforms, and external recipient systems; only documented tenant-side interfaces are modeled.
- Microsoft support service and support-channel data handling, which the public service description places outside the service accreditation boundary.

SYNTHETIC TEST DATA - NOT A VALID ATO

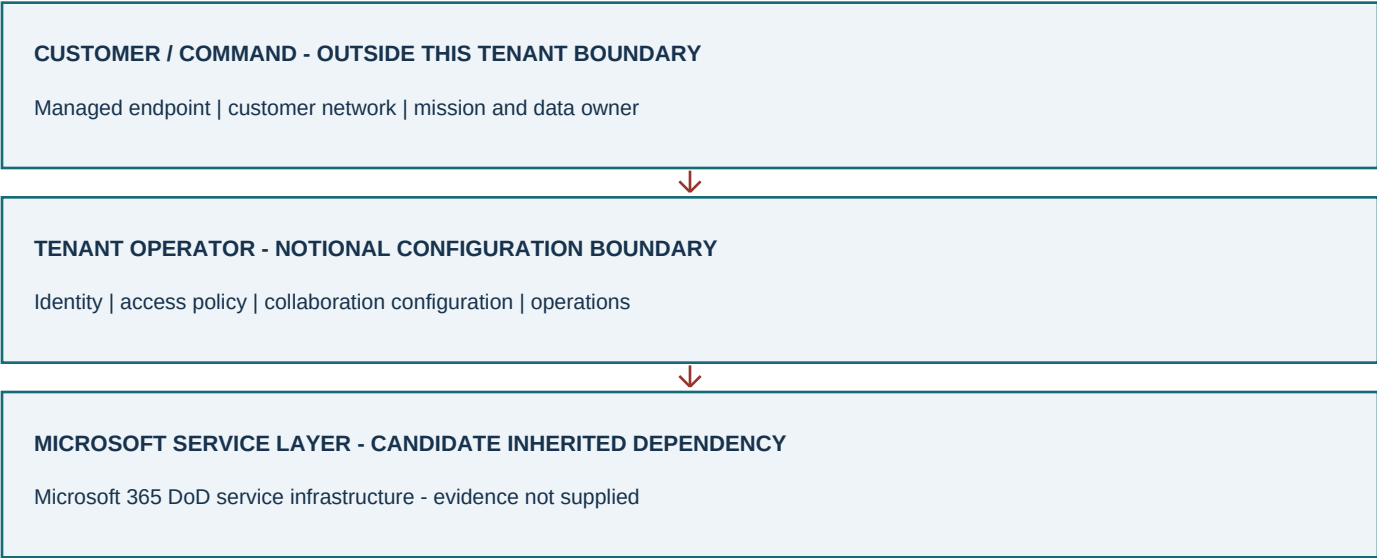
- AI assistants, Microsoft Copilot, AI processing, custom agents, unapproved applications, and application/service-principal integrations.
- An issued authorization, real inherited-control attestation, real assessment result, or claim that a notional target is implemented or effective.

Assumptions requiring validation

- All numbers, dates, timing objectives, rosters, events, sampling plans, and remediation schedules are synthetic planning inputs as of 2026-09-24.
- A notional population consists of 2,400 workforce accounts, 12 privileged assignments, 60 SharePoint sites, 120 Teams workspaces, and 20 guest-collaboration exceptions. These are invented denominators, not discovered inventory.
- Microsoft public documentation establishes Office 365 DoD IL5 context and distinguishes it from GCC High; it does not establish authorization or control inheritance for this fixture.
- Provider implementation statements describe candidate responsibilities requiring current authorization-boundary, service-specific responsibility, cryptographic, and assessment evidence before inheritance.
- Any Purview, Defender, advanced audit, privileged identity management, sensitivity-label enforcement, conditional-access integration, retention, or eDiscovery function requires cloud-specific availability, SKU, licensing, configuration, and authorized-boundary verification before use. Manual procedural alternatives do not prove equivalent technical protection.
- Government-approved identity federation and strong authentication are desired interfaces, not assertions about a deployed CAC/PIV integration or a particular tenant authentication method.
- Retention, recycle bins, version history, and legal holds are purpose-limited features, not universal backups or guaranteed recovery of all mailbox, site, OneDrive, or Teams state.
- The customer retains mission/data-owner approvals, personnel eligibility, endpoint/network controls, privacy determinations, and acceptance of residual risk; the tenant operator cannot assume these from provider documentation.
- Only four invented illustrative evidence samples are supplied. Twelve requested evidence packages are absent. No assessment procedures were executed against a real system.
- The proposed decision dates are scheduling placeholders only. There is no assigned real AO, signature, effective authorization, accepted remediation closure, or permission to operate.

SYNTHETIC TEST DATA - NOT A VALID ATO

2. Boundary and data-flow model



The diagram shows responsibility layers, not Microsoft's actual internal network topology. Arrows are conceptual dependency/data exchanges, not approved interconnections or an assurance of encryption.

Flow / owner	Source to destination	Information / transport	Boundary / approval
FS-FLOW-001 FS-ROLE-003	External customer identity-federation authority to FS-CMP-001	Synthetic workforce identity assertions, role eligibility attributes, and authentication context; never passwords or private keys in evidence. Notional authenticated federation over encrypted transport; exact protocol, endpoints, trust anchors, and cloud support require verification.	External customer identity system to tenant identity-policy boundary. Notional design only; federation agreement and trust validation not supplied.
FS-FLOW-002 FS-ROLE-011	External customer-managed endpoint and posture authority to FS-CMP-007	Synthetic device posture, user context, assertion age, and access decision inputs. Notional encrypted service-to-service assertion and interactive sign-in channels; supported integration must be verified.	Endpoint-management platform remains outside; tenant consumption and enforcement policy are inside. Notional design only; posture interface assurance and customer approval not supplied.
FS-FLOW-003 FS-ROLE-003	FS-CMP-001 to FS-CMP-003	Synthetic authenticated mailbox session context and access decisions, not reusable tokens in the fixture. Service-supported authentication and encrypted client/service channels; actual protocol configuration unverified.	Tenant identity policy to Exchange Online DoD workload access; underlying provider implementation candidate inherited. Notional internal flow; policy baseline and negative-access tests not supplied.

SYNTHETIC TEST DATA - NOT A VALID ATO

Flow / owner	Source to destination	Information / transport	Boundary / approval
FS-FLOW-004 FS-ROLE-007	FS-CMP-003 to External approved recipient collaboration system	Invented non-sensitive test email and attachments; no operational data or CUI. Mail transport subject to verified encryption and recipient-domain policy; no assumption of guaranteed end-to-end encryption.	Tenant messaging service to separately authorized recipient boundary. Notional exchange; recipient approval and technical transport evidence not supplied.
FS-FLOW-005 FS-ROLE-004	FS-CMP-006 to FS-CMP-004	Synthetic channel-document references, permissions, and collaboration content. Service-supported encrypted workload integration; actual service routing and encryption evidence absent.	Teams and SharePoint workload ownership boundary within the proposed tenant scope; permissions must be reconciled. Notional internal flow; cross-workload membership and link tests pending.
FS-FLOW-006 FS-ROLE-007	FS-CMP-005 to External approved guest recipient	Synthetic named-recipient file access and sharing invitations, subject to exception expiry. Authenticated encrypted recipient session if supported and approved; anonymous links are a prohibited notional target.	Tenant personal workspace to external guest identity and device; recipient device is outside. Notional exchange; one invented exception lacks expiry, recorded in FS-FIND-002.
FS-FLOW-007 FS-ROLE-005	FS-CMP-006 to FS-CMP-008	Synthetic Teams administrative, membership, and meeting-policy event metadata, not meeting transcripts. Tenant-accessible audit interfaces subject to service support, licensing, and collection-delay verification.	Workload event production to operator audit reconciliation; provider internal telemetry is not presumed available. Notional flow; missing Teams source coverage is recorded in FS-FIND-003.
FS-FLOW-008 FS-ROLE-005	FS-CMP-008 to External customer security operations evidence repository	Minimized incident-relevant audit records, collection manifest, and custody metadata. Proposed authenticated encrypted export to separately approved storage; no real transfer or external SIEM integration supplied.	Tenant audit boundary to external customer incident-response and evidence-storage boundary. Notional exchange; repository authorization, handling agreement, and export tests not supplied.
FS-FLOW-009 FS-ROLE-006	FS-CMP-010 to FS-CMP-004	Synthetic records classification, disposition suspension, and hold-scope instructions. Proposed authorized administrative policy channel; actual records/hold feature availability and scope require verification.	Customer legal/records decision authority to tenant workload enforcement. Notional internal flow; hold/disposition conflict remains open in FS-FIND-006.

SYNTHETIC TEST DATA - NOT A VALID ATO

Flow / owner	Source to destination	Information / transport	Boundary / approval
FS-FLOW-010 FS-ROLE-009	FS-CMP-012 to External Microsoft support service	Proposed minimized outage description, workload name, approximate timestamp, and sanitized correlation information; no content, secrets, or CUI. Approved support channel only after handling review; channel encryption does not bring support into the service accreditation boundary.	Tenant operational boundary to support service explicitly outside the service accreditation boundary. Notional coordination only; support handling approval not supplied and no request has been sent.

SYNTHETIC TEST DATA - NOT A VALID ATO

3. Roles and responsibility allocation

All organizations and contacts below are scenario roles, not the real Navy chain of command. A CSP administrator is not automatically the mission AO.

Role / ID	Organization / contact	Assigned responsibilities
FS-ROLE-001 Tenant system owner	Synthetic Maritime Collaboration Operations Office system-owner@example.test	Own the proposed tenant boundary, resource remediation, approve internal operational priorities, and route unresolved risk to a separately designated AO. Cannot issue authorization or certify provider inheritance.
FS-ROLE-002 Information system security manager	Synthetic Tenant Assurance Cell issm@example.test	Maintain the forty-control illustrative matrix, evidence register, exception ledger, and POAMs; coordinate assessment readiness and monitoring. Keep all samples separate from accepted operational evidence.
FS-ROLE-003 Identity and privileged-access lead	Synthetic Tenant Identity Operations identity-lead@example.test	Propose account, authentication, administrative-role, and access-policy targets; reconcile command personnel notices; revoke tenant access and coordinate external federation actions.
FS-ROLE-004 Collaboration workload lead	Synthetic Collaboration Operations workload-lead@example.test	Maintain mailbox, site, OneDrive, and Teams configuration baselines; review sharing exceptions; coordinate workload-specific recovery and content-owner verification.
FS-ROLE-005 Security operations duty lead	Synthetic Customer Security Operations soc-duty@example.test	Review tenant-accessible events, reconcile source coverage, triage incidents, preserve relevant records, and hand off external endpoint/network investigations without claiming those systems are inside the tenant boundary.
FS-ROLE-006 Records and privacy coordination officer	Synthetic Records and Privacy Office records-privacy@example.test	Coordinate invented records schedules, legal-hold instructions, privacy authority review, and counsel approval before disposition. This role is not a real attorney, records authority, or legal-hold issuer.
FS-ROLE-007 Customer mission and data owner	Synthetic Supported Mission Directorate mission-owner@example.test	Approve business need, recipient eligibility, data categorization, collaboration membership, and recovery priority; supply personnel and mission decisions retained outside the tenant operator's authority.
FS-ROLE-008 Independent assessment coordinator	Synthetic Assessment Exercise Team assessment@example.test	Plan examine/interview/test sampling, identify evidence gaps, retest proposed closures, and report limitations. Has performed no actual assessment and cannot sign an authorization.
FS-ROLE-009 Provider assurance liaison	Synthetic Customer Supplier Assurance Office provider-liaison@example.test	Request authorized provider evidence through approved channels, reconcile service boundaries and shared duties, and prohibit sensitive content in support requests. This invented customer liaison does not speak for Microsoft.
FS-ROLE-010 Continuity coordinator	Synthetic Mission Continuity Cell continuity@example.test	Maintain outage contacts and workload recovery priorities, plan isolated restoration rehearsals, distinguish provider restoration from customer content recovery, and obtain data-owner reconciliation.

SYNTHETIC TEST DATA - NOT A VALID ATO

Role / ID	Organization / contact	Assigned responsibilities
FS-ROLE-011 External endpoint and network liaison	Synthetic Customer Computing Authority endpoint-liaison@example.test	Supply approved posture assertions and investigate endpoint/network failures outside this boundary; coordinate tenant access restrictions without implying the tenant operator manages endpoints.
FS-ROLE-012 Configuration review chair	Synthetic Tenant Change Board change-chair@example.test	Review policy baselines and change impact, require independent approval and rollback criteria, and reconcile emergency changes with the security manager and records officer.

SYNTHETIC TEST DATA - NOT A VALID ATO

4. Component and capability inventory

Stable identifiers reconcile the repeated PDF, workbook and JSON descriptions. Logical operational components are not fabricated servers. No hardware, subscription, license or live tenant discovery is asserted.

Component	Type / owner	Capabilities
FS-CMP-001 Tenant identity and federation	Logical tenant identity-policy component FS-ROLE-003	FS-CAP-001, FS-CAP-002
FS-CMP-002 Privileged administration	Logical administrative-access governance component FS-ROLE-003	FS-CAP-003, FS-CAP-004
FS-CMP-003 Exchange Online DoD messaging	Logical collaboration workload FS-ROLE-004	FS-CAP-005, FS-CAP-006
FS-CMP-004 SharePoint Online DoD collaboration	Logical collaboration workload FS-ROLE-004	FS-CAP-007, FS-CAP-008
FS-CMP-005 OneDrive DoD individual workspaces	Logical collaboration workload FS-ROLE-004	FS-CAP-009, FS-CAP-010
FS-CMP-006 Teams DoD collaboration and meetings	Logical collaboration workload FS-ROLE-004	FS-CAP-011, FS-CAP-012
FS-CMP-007 Tenant device and access-compliance interface	Logical tenant policy interface FS-ROLE-003	FS-CAP-013, FS-CAP-014
FS-CMP-008 Tenant audit and monitoring	Logical audit-governance component FS-ROLE-005	FS-CAP-015, FS-CAP-016
FS-CMP-009 Information protection and sharing policies	Logical information-governance component FS-ROLE-007	FS-CAP-017, FS-CAP-018
FS-CMP-010 Records retention and legal hold	Logical records-governance component FS-ROLE-006	FS-CAP-019, FS-CAP-020
FS-CMP-011 Configuration and change governance	Logical tenant operational-governance component FS-ROLE-012	FS-CAP-021, FS-CAP-022
FS-CMP-012 Continuity and recovery coordination	Logical continuity-governance component FS-ROLE-010	FS-CAP-023, FS-CAP-024

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-001 | Tenant identity and federation

Logical type / owner: Logical tenant identity-policy component / FS-ROLE-003

Notional, synthetic tenant identity configuration for workforce sign-in and lifecycle coordination. External federation infrastructure and authenticator issuance remain outside the boundary. This inventory entry is not a discovered tenant or proof of deployed authentication.

Notional configuration assumptions

- Target 2,400 workforce accounts with unique identities and command-approved sponsors.
- Target strong authentication for all interactive access; exact government identity integration and policy support require verification.
- Target disablement within four hours of an authoritative termination notice and monthly reconciliation of dormant accounts.

Tenant/provider responsibilities

- Candidate inherited operation of the service-side identity interface and platform availability, subject to service-boundary evidence.
- Supply supported authentication behavior and service security evidence; no provider evidence is supplied here.

Customer retained responsibilities

- Approve users, account purpose, authentication methods, federation trusts, and access exceptions.
- Operate external identity issuance and federation under separate customer authority and retain access-decision evidence.

Evidence references: FS-EV-002, FS-EV-005, FS-EV-006, FS-EV-007

FS-CAP-001 | Workforce identity lifecycle coordination

Notional onboarding, sponsor recertification, dormant-account review, and termination handoff for tenant identities.

Proposed controls / contributors: AC-2, IA-2, PS-4 / FS-CMP-001

Provider implementation assumption: Candidate service-side identity and account-state mechanisms only; current implementation and authorization evidence are not supplied.

Customer actions: Obtain authoritative personnel notices, approve access, reconcile monthly, and verify disablement within the notional four-hour target.

FS-CAP-002 | Federated authentication policy assurance

Notional validation of authentication context, federation trust, and rejected sign-in paths.

Proposed controls / contributors: IA-2, IA-5, AC-17 / FS-CMP-001

Provider implementation assumption: Supported service-side authentication interfaces are candidate inherited mechanisms; exact methods, cloud support, and cryptographic evidence require verification.

Customer actions: Approve external federation authority, strong authentication, trust changes, and nonproduction positive/negative sign-in tests.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-002 | Privileged administration

Logical type / owner: Logical administrative-access governance component / FS-ROLE-003

Notional, synthetic administrative-role governance over twelve invented assignments. Separate administrative identities, dual review, and emergency access are design targets, not implemented protections. Privileged-management products are not presumed licensed or available.

Notional configuration assumptions

- Target twelve privileged assignments reviewed monthly by a reviewer other than the assignee.
- Target routine elevations lasting no more than four hours where a verified supported mechanism exists; otherwise an explicitly approved manual grant/revoke workflow is required.
- Target two separately controlled emergency-access identities with quarterly non-disruptive exercises; no credentials are included.

Tenant/provider responsibilities

- Candidate operation of tenant role-enforcement primitives; supported granular roles and activation features require verification.
- Provide role-assignment audit semantics and service-side administrative assurance within the actual authorized service boundary.

Customer retained responsibilities

- Justify assignments, segregate duties, verify removal, and protect emergency authentication materials outside this fixture.
- Resolve the two invented overdue assignment reviews before claiming review completeness.

Evidence references: FS-EV-001, FS-EV-002, FS-EV-006, FS-EV-007

FS-CAP-003 | Least-privilege assignment review

Notional monthly independent review of twelve administrative assignments and their mission justification.

Proposed controls / contributors: AC-2, AC-3, AC-6 / FS-CMP-002

Provider implementation assumption: Service role-enforcement primitives are candidate provider duties; no automated privileged-access product is assumed available.

Customer actions: Use separate administrator identities, review all assignments, remove unjustified privileges, and resolve the two synthetic overdue reviews.

FS-CAP-004 | Emergency administrative access accountability

Notional dual-controlled emergency access with immediate notification and next-business-day independent review.

Proposed controls / contributors: AC-6, IA-5, AU-6, IR-4 / FS-CMP-002

Provider implementation assumption: Supported administrative sign-in and role-audit behavior require verification; optional activation tooling needs cloud/SKU confirmation.

Customer actions: Assign two custodians, secure authenticators, rehearse quarterly, and revoke emergency privileges after use without logging credentials.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-003 | Exchange Online DoD messaging

Logical type / owner: Logical collaboration workload / FS-ROLE-004

Notional, synthetic Exchange Online DoD mailbox and mail-flow policy scope. Mailbox populations, transport restrictions, and delegation settings are planning values only. No live mailbox, transport test, service attestation, or tenant authorization is represented.

Notional configuration assumptions

- Target external automatic forwarding disabled unless a named mission owner approves a time-bounded exception.
- Target monthly review of shared-mailbox delegates and mail-flow rules, sampling ten mailboxes and five rules per cycle.
- Target transport encryption verification for approved external exchange paths without asserting universal end-to-end encryption.

Tenant/provider responsibilities

- Candidate inherited messaging infrastructure operation, service patching, and platform protection, pending authorization evidence.
- Document supported mail-flow controls, recovery limits, and service-side encryption applicable to the DoD offering.

Customer retained responsibilities

- Configure recipient restrictions, mailbox delegation, transport rules, and exception expiry.
- Classify outbound content, authorize recipient relationships, and coordinate mailbox records/recovery requirements.

Evidence references: FS-EV-003, FS-EV-004, FS-EV-005, FS-EV-006, FS-EV-010, FS-EV-015

FS-CAP-005 | Controlled mail routing

Notional restriction and review of external forwarding, transport rules, and approved recipient paths.

Proposed controls / contributors: AC-4, CA-3, SC-8 / FS-CMP-003

Provider implementation assumption: Messaging transport and supported mail-flow policy enforcement are candidate provider mechanisms; actual encryption paths remain unverified.

Customer actions: Default-deny automatic external forwarding, approve exceptions, and test five representative rules without operational content.

FS-CAP-006 | Mailbox delegation accountability

Notional control of shared-mailbox delegates, owner approval, and departure revocation.

Proposed controls / contributors: AC-2, AC-3, PS-4 / FS-CMP-003

Provider implementation assumption: Mailbox authorization primitives are candidate service responsibilities, not evidence of correct customer delegation.

Customer actions: Reconcile ten mailbox samples monthly against mission-approved delegates and revoke departed-user access before records disposition.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-004 | SharePoint Online DoD collaboration

Logical type / owner: Logical collaboration workload / FS-ROLE-004

Notional, synthetic inventory of sixty collaboration sites, site-owner responsibilities, and named-recipient sharing targets. This describes proposed tenant governance, not actual Navy sites, deployed policies, or verified content-access enforcement.

Notional configuration assumptions

- Target sixty sites with two accountable owners each and quarterly access recertification.
- Target anonymous sharing disabled and external sharing denied unless a documented, expiring mission exception permits it.
- Target monthly review of ten sites, all privileged site changes, and every exception approaching expiry within seven days.

Tenant/provider responsibilities

- Candidate inherited operation of SharePoint storage and access-control primitives, pending service-specific evidence.
- Document supported version, recycle-bin, sharing, and recovery behavior without implying comprehensive backup.

Customer retained responsibilities

- Approve site membership, data classification, external recipients, and ownership handoffs.
- Validate permission inheritance, sharing links, records scope, and content recovery against mission needs.

Evidence references: FS-EV-003, FS-EV-004, FS-EV-005, FS-EV-006, FS-EV-008, FS-EV-010

FS-CAP-007 | Site permission and owner governance

Notional owner assignment, group-based access, and permission-inheritance review for sixty sites.

Proposed controls / contributors: AC-3, AC-6, CM-8 / FS-CMP-004

Provider implementation assumption: SharePoint permission evaluation is a candidate service mechanism; configuration and inheritance correctness remain customer duties.

Customer actions: Maintain two owners per site, recertify quarterly, and test ten sites for unauthorized or inherited access.

FS-CAP-008 | Named-recipient site sharing

Notional restriction of document sharing to approved recipients and expiring exceptions.

Proposed controls / contributors: AC-4, AC-20, CA-3 / FS-CMP-004

Provider implementation assumption: Supported recipient/link controls require verification for the DoD offering and actual tenant configuration.

Customer actions: Prohibit anonymous links, record sponsors and expiry, and retest expired links against denied-access expectations.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-005 | OneDrive DoD individual workspaces

Logical type / owner: Logical collaboration workload / FS-ROLE-004

Notional, synthetic individual document-workspace policies for the invented workforce. Sharing and departure recovery are coordinated with mission and records owners. No actual personal files, account exports, or service recovery guarantees are supplied.

Notional configuration assumptions

- Target named-recipient sharing only, with external sharing default-denied and exception expiration no longer than thirty days.
- Target departure ownership decisions within one business day of notice, before account-content disposition.
- Target ten randomly selected active workspaces and every departing privileged user's workspace in each monthly review.

Tenant/provider responsibilities

- Candidate inherited operation of workspace storage and available lifecycle features, pending service-boundary evidence.
- Document actual deletion, versioning, restore, and hold interaction limits for the verified DoD service configuration.

Customer retained responsibilities

- Approve workspace recipients, prohibit using personal workspaces as an undocumented system of record, and enforce owner handoff.
- Reconcile departure access revocation with legal holds and supported content preservation.

Evidence references: FS-EV-002, FS-EV-005, FS-EV-006, FS-EV-008, FS-EV-010, FS-EV-011

FS-CAP-009 | Individual-workspace sharing restrictions

Notional recipient-limited OneDrive collaboration governed by mission approval and expiry.

Proposed controls / contributors: AC-3, AC-4, AC-20 / FS-CMP-005

Provider implementation assumption: Workspace sharing controls are candidate service capabilities; exact feature availability and enforcement are unverified.

Customer actions: Review ten workspaces monthly, default-deny external sharing, and use only approved named-recipient exceptions.

FS-CAP-010 | Departing-user content handoff

Notional separation of immediate access revocation from authorized content preservation and ownership transfer.

Proposed controls / contributors: PS-4, CP-9, MP-6 / FS-CMP-005

Provider implementation assumption: Supported lifecycle, preservation, and deletion behavior requires service-specific evidence; no recovery guarantee is implied.

Customer actions: Notify data and records owners, preserve held content through a verified mechanism, assign a successor, and record authorized disposition.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-006 | Teams DoD collaboration and meetings

Logical type / owner: Logical collaboration workload / FS-ROLE-004

Notional, synthetic configuration scope for 120 Teams workspaces, membership, meeting admission, and linked content. Voice interconnects, third-party apps, AI/Copilot services, and external network operations are excluded.

Notional configuration assumptions

- Target two accountable owners for each of 120 workspaces and quarterly membership review.
- Target external federation and guest admission restricted to approved relationships; anonymous meeting admission denied unless separately authorized.
- Target verification of content-location and retention dependencies with Exchange, SharePoint, and OneDrive; exact workload storage behavior requires review.

Tenant/provider responsibilities

- Candidate inherited service operation and supported meeting/membership controls, subject to actual authorized service scope.
- Provide verified audit-event, retention, and recovery limitations for Teams DoD rather than commercial-cloud assumptions.

Customer retained responsibilities

- Approve membership, guest/federation relationships, meeting policy, and content handling.
- Reconcile linked workload permissions and address audit-source coverage and recovery gaps.

Evidence references: FS-EV-001, FS-EV-005, FS-EV-006, FS-EV-008, FS-EV-009, FS-EV-011

FS-CAP-011 | Workspace membership and federation governance

Notional Teams owner, member, guest, and external relationship review across 120 workspaces.

Proposed controls / contributors: AC-2, AC-20, CA-3 / FS-CMP-006

Provider implementation assumption: Supported Teams membership and federation interfaces are candidate provider responsibilities; no commercial-cloud feature parity is assumed.

Customer actions: Maintain accountable owners, reconcile membership quarterly, and approve external relationships before enabling access.

FS-CAP-012 | Meeting admission and collaboration policy

Notional meeting admission restrictions and linked-content permission verification.

Proposed controls / contributors: AC-3, AC-4, AU-2 / FS-CMP-006

Provider implementation assumption: Meeting-policy enforcement and available event generation require DoD service/SKU verification; unavailable events must be documented as gaps.

Customer actions: Deny unapproved anonymous admission, validate attendee permissions, and reconcile meeting-policy events with the audit source matrix.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-007 | Tenant device and access-compliance interface

Logical type / owner: Logical tenant policy interface / FS-ROLE-003

Notional, synthetic tenant-side access decisions consuming external identity and device-posture signals. The endpoint-management platform, endpoint agents, patching, disks, and customer networks are expressly outside this component.

Notional configuration assumptions

- Target access denial for absent or stale posture on protected sessions, after verifying the available tenant policy mechanism.
- Notional freshness target is twenty-four hours; test compliant, noncompliant, unknown, and stale states.
- Any conditional-access or device integration depends on verified DoD cloud availability, SKU, licenses, and customer authority.

Tenant/provider responsibilities

- Candidate operation of supported tenant access-policy evaluation interfaces, not customer endpoint management.
- Document claim handling, evaluation timing, and failure behavior for supported configurations.

Customer retained responsibilities

- Approve access conditions and handle fail-closed exceptions through the tenant operator.
- Have the external computing authority attest endpoint posture and remediate endpoint/network defects under its separate boundary.

Evidence references: FS-EV-005, FS-EV-006, FS-EV-007, FS-EV-014, FS-EV-015

FS-CAP-013 | Posture-aware tenant access decisions

Notional tenant enforcement using externally asserted device compliance and authentication context.

Proposed controls / contributors: AC-17, AC-20, SC-7 / FS-CMP-007

Provider implementation assumption: A supported access-policy engine is a candidate service mechanism only after cloud/SKU and integration verification.

Customer actions: Approve posture conditions, deny unknown/stale assertions, test four device states, and hand endpoint defects to the external computing authority.

FS-CAP-014 | Access-interface assurance handoff

Notional reconciliation of tenant denials, external posture defects, and separately owned remediation.

Proposed controls / contributors: CA-3, RA-5, SI-2 / FS-CMP-007

Provider implementation assumption: Provider documents policy evaluation behavior and service defects; customer endpoint vulnerability management is not inherited.

Customer actions: Track stale-signal defects, assign an external liaison, preserve tenant-side denial evidence, and retest after customer remediation.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-008 | Tenant audit and monitoring

Logical type / owner: Logical audit-governance component / FS-ROLE-005

Notional, synthetic tenant event-source inventory, audit review, and investigation interface. Optional advanced audit, Defender, external SIEM, or other security products are not presumed present; only verified accessible events may be used.

Notional configuration assumptions

- Target eight source categories with daily source-presence checks and alert triage within thirty minutes of ingestion.
- Target ninety days of searchable audit and one year of protected retention only where verified licensing, export, and external storage arrangements support them.
- Target record fields include event time, ingestion time, source, actor alias, target alias, operation, outcome, and correlation reference.

Tenant/provider responsibilities

- Candidate generation and availability of supported tenant-visible events and documented service retention limits.
- Provider internal telemetry is separate and not assumed accessible or inherited as customer review evidence.

Customer retained responsibilities

- Reconcile sources, preserve records, restrict audit access, review events, and coordinate incidents.
- Validate retention/export arrangements and independently document absent or delayed event sources.

Evidence references: FS-EV-001, FS-EV-005, FS-EV-009, FS-EV-012

FS-CAP-015 | Audit source and retention reconciliation

Notional source presence, required field completeness, searchable retention, and export coverage checks.

Proposed controls / contributors: AU-2, AU-3, AU-9, AU-11 / FS-CMP-008

Provider implementation assumption: Only documented tenant-visible event categories and licensed retention features may support inheritance; advanced audit availability requires verification.

Customer actions: Reconcile eight source categories daily, identify unavailable sources, and demonstrate retrieval at the approved retention boundary.

FS-CAP-016 | Security event triage and escalation

Notional review of administrative changes, denied access, sharing activity, and incident indicators.

Proposed controls / contributors: AU-6, IR-4, IR-6, CA-7 / FS-CMP-008

Provider implementation assumption: Service telemetry and provider incident communications are candidate inputs; optional Defender/SIEM integration requires independent verification.

Customer actions: Triage high-priority events within thirty minutes of ingestion, document dispositions, and route incidents to mission and external system owners.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-009 | Information protection and sharing policies

Logical type / owner: Logical information-governance component / FS-ROLE-007

Notional, synthetic classification, recipient approval, and sharing restrictions across collaboration workloads. Sensitivity labels, DLP, Purview, and other optional enforcement functions are conditional on cloud/SKU verification and are not asserted to exist.

Notional configuration assumptions

- Use only invented Public Exercise and Internal Exercise markings for test content; no real CUI is processed.
- Target twenty guest-sharing exceptions, each with sponsor, recipient, content purpose, approval, expiry, and revocation verification.
- Target a maximum thirty-day guest exception and weekly review of exceptions; classification does not itself enforce access.

Tenant/provider responsibilities

- Provide supported sharing and information-protection primitives where verified for the actual service offering and license.
- Explain enforcement coverage and limitations across workloads; no automatic parity across Exchange, SharePoint, OneDrive, and Teams is assumed.

Customer retained responsibilities

- Determine content sensitivity, lawful sharing purpose, recipient eligibility, and approval conditions.
- Test actual enforcement where available and use approved restrictions rather than silently relying on unsupported product features.

Evidence references: FS-EV-003, FS-EV-006, FS-EV-008, FS-EV-013, FS-EV-015

FS-CAP-017 | Content classification and handling governance

Notional data-owner classification and handling instructions using only invented exercise content.

Proposed controls / contributors: AC-4, AT-2, PT-2, SC-28 / FS-CMP-009

Provider implementation assumption: Optional label/DLP/Purview functions are conditional on verified cloud, SKU, enforcement coverage, and authorized boundary.

Customer actions: Determine lawful purpose and data categories, train users, approve recipients, and test any actual enforcement rather than equating labels with protection.

FS-CAP-018 | Sharing exception lifecycle

Notional sponsorship, expiry, recertification, and revocation of approved external collaboration exceptions.

Proposed controls / contributors: AC-20, CA-3, AC-4 / FS-CMP-009

Provider implementation assumption: Available sharing restrictions and revocation behavior must be documented; no particular automated exception workflow is assumed.

Customer actions: Review all twenty invented exceptions weekly, set at most thirty-day expiry, and verify denial after expiration or sponsor withdrawal.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-010 | Records retention and legal hold

Logical type / owner: Logical records-governance component / FS-ROLE-006

Notional, synthetic records scheduling, disposition suspension, and legal-hold coordination. Any retention/eDiscovery/Purview mechanism requires verified DoD cloud/SKU support. Neither retention nor hold is characterized as a complete backup or recovery solution.

Notional configuration assumptions

- Illustrative schedules propose two years for routine exercise correspondence and seven years for selected exercise decision records; these are not approved government schedules.
- Target suspension of disposition for a documented hold until authorized release and reconciliation across affected workloads.
- Target monthly review of hold scopes, custodians, expiry logic, and policy conflicts before content disposition.

Tenant/provider responsibilities

- Document supported retention, preservation, deletion, and hold behavior for licensed, authorized services.
- Provide service-side storage/media-disposal evidence; tenant deletion does not prove physical sanitization.

Customer retained responsibilities

- Obtain valid records/privacy/legal authority and translate it into verified workload-specific policy.
- Resolve conflicting disposition instructions and record release approval before deleting held content.

Evidence references: FS-EV-003, FS-EV-005, FS-EV-010, FS-EV-013

FS-CAP-019 | Records schedule and disposition coordination

Notional translation of authorized records schedules into verified workload retention and disposition rules.

Proposed controls / contributors: AU-11, MP-6, CM-3 / FS-CMP-010

Provider implementation assumption: Supported retention/deletion mechanisms and media handling require provider evidence; optional records features require cloud/SKU verification.

Customer actions: Obtain schedule authority, distinguish audit from business-content retention, detect conflicting rules, and retain disposition approvals.

FS-CAP-020 | Legal-hold preservation coordination

Notional authorization, scoping, testing, and release of preservation instructions across affected workloads.

Proposed controls / contributors: MP-6, PT-2, CP-9 / FS-CMP-010

Provider implementation assumption: Hold/eDiscovery preservation behavior is conditional on verified DoD availability and licensing and is not a general backup guarantee.

Customer actions: Obtain authorized hold instructions, suspend conflicting disposition, verify preservation, and require counsel/records release before deletion.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-011 | Configuration and change governance

Logical type / owner: Logical tenant operational-governance component / FS-ROLE-012

Notional, synthetic tenant baseline, inventory, and change-review process. The component inventories logical Microsoft 365 policies and responsibilities, not virtual machines, appliances, Azure subscriptions, or real discovered assets.

Notional configuration assumptions

- Target a versioned twelve-component inventory and policy baseline reviewed monthly.
- Target independent approval, rollback criteria, security/privacy impact, and post-change verification for every policy change.
- Target emergency review within one business day and drift triage within two business days.

Tenant/provider responsibilities

- Communicate supported service changes and customer-visible configuration effects through verified channels.
- Maintain underlying platform configuration under candidate inherited provider processes rather than customer change-board control.

Customer retained responsibilities

- Control tenant policy changes, maintain accurate scope and responsibility records, and compare intended versus observed settings.
- Assess shared-workload, retention, guest, and audit impacts before promoting a policy revision.

Evidence references: FS-EV-003, FS-EV-006, FS-EV-014, FS-EV-015, FS-EV-016

FS-CAP-021 | Tenant baseline and component inventory

Notional versioned policy settings, logical service inventory, dependencies, and shared-duty register.

Proposed controls / contributors: CM-2, CM-6, CM-8, PL-2 / FS-CMP-011

Provider implementation assumption: Provider documents supported service settings and boundary changes; its internal asset inventory is not customer tenant inventory.

Customer actions: Maintain twelve logical entries with owners, twenty-four capabilities, approved settings, interface dependencies, and unresolved evidence status.

FS-CAP-022 | Policy change and drift governance

Notional impact analysis, independent approval, controlled rollout, rollback, and drift follow-up.

Proposed controls / contributors: CM-3, CM-6, CA-7, SI-2 / FS-CMP-011

Provider implementation assumption: Provider manages underlying service changes and advisories; the tenant board controls only customer-configurable settings.

Customer actions: Review security/privacy and records impacts, record before/after settings, verify rollback, and triage unauthorized drift within two business days.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-CMP-012 | Continuity and recovery coordination

Logical type / owner: Logical continuity-governance component / FS-ROLE-010

Notional, synthetic outage communication and workload-specific restoration coordination. Provider availability, tenant content recovery, and external customer continuity are separate responsibilities. No third-party backup system or guaranteed SaaS recovery is included.

Notional configuration assumptions

- Notional mission targets: communicate an outage within thirty minutes, restore priority collaboration within twenty-four hours, and limit priority content loss to twenty-four hours where technically supported.
- Verify each workload's available recovery mechanisms, dependencies, rights, retention windows, and unrecoverable object types before adopting targets.
- Target quarterly isolated recovery rehearsals covering mailbox items, site files/permissions, OneDrive handoff, and Teams membership/content references.

Tenant/provider responsibilities

- Provide service continuity, outage communication, and documented recovery limits under the actual service arrangement.
- Handle underlying service recovery; no customer recovery objective is presumed guaranteed by public IL5 descriptions.

Customer retained responsibilities

- Approve mission recovery priorities, preserve suitable recovery sources, rehearse tenant actions, and obtain data-owner acceptance.
- Coordinate external continuity alternatives and sanitized support escalation without exporting sensitive data into an unapproved boundary.

Evidence references: FS-EV-004, FS-EV-005, FS-EV-011, FS-EV-012, FS-EV-015

FS-CAP-023 | Outage communication and continuity coordination

Notional mission-priority communication, external continuity handoffs, and sanitized provider escalation.

Proposed controls / contributors: CP-2, CP-4, IR-6, SA-9 / FS-CMP-012

Provider implementation assumption: Provider service recovery and notifications are candidate contracted duties; support remains outside the service accreditation boundary.

Customer actions: Notify mission owners within thirty minutes, activate separately approved alternatives, and send only reviewed minimized support details.

FS-CAP-024 | Workload recovery rehearsal and reconciliation

Notional testing of content, permissions, ownership, and cross-workload references against mission recovery targets.

Proposed controls / contributors: CP-4, CP-9, CP-10 / FS-CMP-012

Provider implementation assumption: Only verified service recovery mechanisms and limits may be relied upon; retention/version history is not blanket backup.

Customer actions: Exercise four workload classes quarterly using inert artifacts, record unsupported states, and obtain independent data-owner reconciliation before closure.

SYNTHETIC TEST DATA - NOT A VALID ATO

5. Control implementation and assessment crosswalk

The following forty parent controls are selected examples. Enhancements, organization-defined parameters, privacy/NSS overlays and service-level inheritance require a real tailored baseline. No omitted control is implicitly satisfied or not applicable.

Control	Responsibility	Open finding references
AC-2 Account Management	Shared: tenant identity operator; customer personnel/data owners; candidate provider account-state enforcement.	FS-FIND-001
AC-3 Access Enforcement	Shared: tenant workload and identity operators; customer data owners; candidate provider permission enforcement.	FS-FIND-002
AC-4 Information Flow Enforcement	Shared: tenant sharing/mail-flow operators; customer mission/data owners; candidate provider routing and sharing mechanisms.	FS-FIND-002
AC-6 Least Privilege	Shared: tenant privileged-access lead; customer approving managers; candidate provider administrative-role primitives.	FS-FIND-001
AC-17 Remote Access	Shared: tenant access-policy operator; external customer endpoint/network authorities; candidate provider session interfaces.	No finding modeled; not evidence of effectiveness
AC-20 Use of External Systems	Shared: customer mission/data owner; tenant access/sharing operators; candidate provider external-access controls.	FS-FIND-002
AT-2 Literacy Training and Awareness	Shared: customer training and mission authorities; tenant operator for service-specific guidance; provider for candidate service notices.	No finding modeled; not evidence of effectiveness
AU-2 Event Logging	Shared: tenant SOC for event selection and reconciliation; provider for supported tenant-visible events; customer for external systems.	FS-FIND-003
AU-3 Content of Audit Records	Shared: provider for supported source fields; tenant SOC for completeness checks; customer privacy owner for minimization.	FS-FIND-003

SYNTHETIC TEST DATA - NOT A VALID ATO

Control	Responsibility	Open finding references
AU-6 Audit Record Review, Analysis, and Reporting	Shared: tenant SOC for review and reporting; provider for available telemetry/advisories; customer mission and incident authorities.	FS-FIND-003
AU-9 Protection of Audit Information	Shared: tenant SOC/identity operators for access; provider for candidate service protection; external repository owner for exported copies.	No finding modeled; not evidence of effectiveness
AU-11 Audit Record Retention	Shared: tenant SOC and records officer; provider for supported service retention; external repository owner if separately approved.	FS-FIND-003, FS-FIND-006
CA-2 Control Assessments	Shared: independent customer assessor and security manager; provider for authorized service evidence; AO separately designated.	No finding modeled; not evidence of effectiveness
CA-3 Information Exchange	Shared: customer exchange authorities and mission owners; tenant operator for local restrictions; provider for service interfaces.	FS-FIND-002
CA-7 Continuous Monitoring	Shared: tenant security manager and monitoring owners; customer risk authorities; provider for candidate service-change and assurance inputs.	No finding modeled; not evidence of effectiveness
CM-2 Baseline Configuration	Shared: tenant change board and workload leads; provider for service defaults and changes; customer mission/privacy authorities.	No finding modeled; not evidence of effectiveness
CM-3 Configuration Change Control	Shared: tenant change board and implementers; customer records/data owners; provider for underlying service changes.	FS-FIND-006
CM-6 Configuration Settings	Shared: tenant workload and identity operators; provider for supported setting semantics; customer risk owner for exceptions.	No finding modeled; not evidence of effectiveness
CM-8 System Component Inventory	Shared: tenant inventory custodian; provider for service-scope documentation; customer owners for external dependencies.	No finding modeled; not evidence of effectiveness

SYNTHETIC TEST DATA - NOT A VALID ATO

Control	Responsibility	Open finding references
CP-2 Contingency Plan	Shared: customer continuity and mission owners; tenant workload operators; provider for candidate service continuity.	FS-FIND-004
CP-4 Contingency Plan Testing	Shared: tenant continuity coordinator and independent tester; customer data owners; provider for documented recovery support.	FS-FIND-004
CP-9 System Backup	Shared: customer continuity/data owners for recoverability needs; tenant operators for supported recovery sources; provider for documented service mechanisms.	FS-FIND-004
CP-10 System Recovery and Reconstitution	Shared: tenant continuity/workload operators; customer mission/data owners; provider for underlying service restoration.	FS-FIND-004
IA-2 Identification and Authentication (Organizational Users)	Shared: tenant identity operator; external customer identity issuer; provider for supported authentication mechanisms.	FS-FIND-001
IA-5 Authenticator Management	Shared: customer authenticator issuer and custodians; tenant identity operator; provider for supported revocation/session behavior.	No finding modeled; not evidence of effectiveness
IR-4 Incident Handling	Shared: customer incident authority and tenant SOC; provider for service incidents; external endpoint/network owners.	No finding modeled; not evidence of effectiveness
IR-6 Incident Reporting	Shared: customer reporting authority and tenant SOC; provider for its service notices; mission owner for impact statements.	No finding modeled; not evidence of effectiveness
MA-2 Controlled Maintenance	Shared: provider for underlying SaaS maintenance; tenant operator for advisory/change coordination; customer for external endpoint maintenance.	FS-FIND-005
MP-6 Media Sanitization	Shared: provider for physical service media; tenant records/workload operators for logical disposition; customer for endpoint/export media.	FS-FIND-006

SYNTHETIC TEST DATA - NOT A VALID ATO

Control	Responsibility	Open finding references
PE-3 Physical Access Control	Shared allocation: candidate provider data-center physical controls; customer facilities for external user/administrator locations; tenant liaison for inheritance verification.	FS-FIND-005
PL-2 System Security and Privacy Plans	Shared: customer system owner, security manager, and privacy officer; provider for applicable shared-responsibility inputs.	No finding modeled; not evidence of effectiveness
PS-4 Personnel Termination	Shared: customer personnel and mission authorities; tenant identity/workload operators; provider for supported account/session actions.	No finding modeled; not evidence of effectiveness
PT-2 Authority to Process Personally Identifiable Information	Shared: customer privacy/legal and mission authorities; tenant operator for approved handling; provider for service processing terms.	FS-FIND-002
RA-5 Vulnerability Monitoring and Scanning	Shared: provider for SaaS platform vulnerability management; tenant operator for configuration exposure review; external customer endpoint owner.	FS-FIND-005
SA-9 External System Services	Shared: customer supplier assurance and system owner; provider for contracted service protections; tenant operator for retained duties.	FS-FIND-005
SC-7 Boundary Protection	Shared: provider for SaaS service boundaries; tenant operator for identity/sharing/access-policy interfaces; customer for external networks.	FS-FIND-005
SC-8 Transmission Confidentiality and Integrity	Shared: provider for service transport mechanisms; tenant operator for configurable exchange policies; customer recipient/network authorities.	FS-FIND-005
SC-13 Cryptographic Protection	Shared: provider for service cryptographic mechanisms; tenant operator for supported configuration; customer security authority for required protection.	FS-FIND-005

SYNTHETIC TEST DATA - NOT A VALID ATO

Control	Responsibility	Open finding references
SC-28 Protection of Information at Rest	Shared: provider for candidate service storage protection; tenant operator for permissions and handling; customer for exported/endpoint copies.	FS-FIND-005
SI-2 Flaw Remediation	Shared: provider for SaaS platform flaws; tenant operator for configurable-policy defects; customer endpoint/network owners for external flaws.	FS-FIND-005

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-2 | Account Management

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant identity operator; customer personnel/data owners; candidate provider account-state enforcement.

The notional operator would create workforce accounts only after the mission owner supplies an approved sponsor, role purpose, and eligibility notice. Monthly reconciliation would compare the invented workforce population with personnel notices, mailbox delegates, Teams memberships, and privileged assignments. Dormant or departed accounts would be restricted through a documented workflow, while records owners separately decide content preservation. Microsoft would supply candidate service-side account-state mechanisms; it would not approve mission eligibility or perform the customer's recertification. External identity authorities retain federation and personnel duties. The included access worksheet illustrates two overdue administrative reviews, not a live directory export. No account management outcome or implementation has been verified.

Notional organization-defined parameters

Notional targets: 2,400 workforce accounts; all 12 privileged assignments reviewed monthly; 30 ordinary accounts sampled monthly; dormancy review after 45 days; termination disablement within 4 hours of authoritative notice.

Examine / interview / test

Examine the full privileged roster and 30 ordinary lifecycle cases against approval and termination records. Interview the identity lead and mission owner about notice handoffs. Test create, modify, disable, and expired-sponsor cases with four nonproduction identities; verify linked workload access without deleting preserved content.

Acceptance criterion

All 12 privileged assignments have current independent reviews; all 30 sampled ordinary accounts have a valid sponsor and purpose; every tested termination loses tenant access within 4 hours; any exception or unresolved access is a failure. The synthetic worksheet alone cannot satisfy this criterion.

Evidence: FS-EV-002, FS-EV-007, FS-EV-013

Known modeled gaps: FS-FIND-001

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-3 | Access Enforcement

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant workload and identity operators; customer data owners; candidate provider permission enforcement.

The notional workload lead would translate data-owner approvals into mailbox delegation, site groups, OneDrive recipients, and Teams membership rather than relying on broad tenant membership. Each administrative change would have a request, approving owner, and verification of the resulting access. Test identities representing an owner, authorized member, unapproved guest, and former member would exercise the same inert content across workload boundaries. Microsoft would provide candidate authorization primitives, while the operator remains responsible for selecting and validating tenant permissions. External recipient eligibility and device protection remain customer duties. Sharing exceptions would never override a missing data-owner decision. The fictional guest-expiry gap prevents a complete access-enforcement assurance claim.

Notional organization-defined parameters

Notional monthly sample: 10 mailboxes, 10 sites, 10 OneDrive workspaces, and 10 Teams; four identity classes per selected test object; default deny for unapproved guests.

Examine / interview / test

Examine approved permissions and effective-access exports for the sampled workloads. Interview workload owners about nested groups and link inheritance. Test positive member access and negative guest/former-member access to inert objects, including a Teams-linked SharePoint document.

Acceptance criterion

Every allowed access matches a documented owner-approved entitlement, and every unapproved or revoked identity is denied. Any unauthorized read, download, delegation, or membership change fails the affected path; policy screenshots alone do not pass.

Evidence: FS-EV-006, FS-EV-007, FS-EV-008

Known modeled gaps: FS-FIND-002

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-4 | Information Flow Enforcement

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant sharing/mail-flow operators; customer mission/data owners; candidate provider routing and sharing mechanisms.

The notional operator would maintain an approved flow register connecting each recipient relationship to data purpose, content handling, and expiry. Mail forwarding, site links, individual workspace sharing, and Teams external collaboration would be evaluated as distinct paths rather than one universal switch. Microsoft would supply candidate transport and sharing mechanisms within its documented service scope; optional classification or DLP enforcement would require cloud and SKU verification. The customer data owner retains authority to release information, and recipient systems remain outside this boundary. Invented exercise markings support tests but are not CUI labels. Missing exception expiry would trigger restriction of the affected path until approval and negative-access tests are documented.

Notional organization-defined parameters

Notional targets: automatic external forwarding denied by default; anonymous links prohibited; guest exception maximum 30 days; test 5 mail rules and 10 links across SharePoint/OneDrive plus 5 external Teams relationships monthly.

Examine / interview / test

Examine the flow register, rules, link types, and exception ledger. Interview data owners about release authority and prohibited destinations. Test approved and unapproved recipients using inert mail and documents, including an expired link and a prohibited forwarding destination.

Acceptance criterion

Every sampled external path has current approval and expiry; prohibited destinations, anonymous access, and expired exceptions are denied in every negative test. Any optional enforcement claim must include verified service availability and execution evidence.

Evidence: FS-EV-003, FS-EV-006, FS-EV-008, FS-EV-015

Known modeled gaps: FS-FIND-002

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-6 | Least Privilege

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant privileged-access lead; customer approving managers; candidate provider administrative-role primitives.

The notional identity lead would map each administrative task to the narrowest verified role and a separate administrative identity. Broad roles would require an explicit justification, independent approval, and review of alternate permissions. Routine elevation would be time bounded using a supported mechanism, or an approved manual grant-and-revoke process if optional privileged-management features are unavailable. Microsoft would enforce candidate role primitives but would not determine the customer's mission need. Customer managers retain eligibility and separation-of-duty decisions. Emergency access would require dual custody and immediate review. Two invented assignments lack current review, so this scenario deliberately cannot support a least-privilege conclusion even though the intended workflow is described.

Notional organization-defined parameters

Notional targets: 12 assignments reviewed monthly; routine elevation no longer than 4 hours where technically supported; 2 emergency identities; emergency-use independent review by next business day.

Examine / interview / test

Examine all assignments, role justifications, expiry records, and emergency-access custody instructions. Interview assignees and independent reviewers. Test one limited-role administrative action, one prohibited action, one expiry/revocation, and an isolated emergency-access notification path.

Acceptance criterion

All assignments have current business justification and independent approval; limited identities cannot perform prohibited actions; revoked/elevated access terminates within its approved window; emergency use produces review evidence. Either overdue review is a failure.

Evidence: FS-EV-001, FS-EV-002, FS-EV-007

Known modeled gaps: FS-FIND-001

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-17 | Remote Access

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant access-policy operator; external customer endpoint/network authorities; candidate provider session interfaces.

The notional operator would authorize remote access by workforce role, authentication context, and verified posture input rather than treating the internet-facing service as unrestricted. Administrative and ordinary sessions would receive distinct policy scrutiny, with exceptions recorded before access is granted. The tenant boundary includes policy evaluation and access decisions, not customer networks, endpoint software, or remote-access appliances. Microsoft would provide candidate service-side authentication and session mechanisms; exact policy capabilities require DoD cloud and license verification. Customer endpoint and network authorities retain transport-path and device assurance. Unknown or stale posture would be treated as denied until resolved. These are proposed conditions, not evidence of a deployed remote-access architecture.

Notional organization-defined parameters

Notional targets: strong authentication for every interactive session; posture assertion age at most 24 hours; review all remote-access exceptions monthly; test compliant, noncompliant, unknown, and stale posture states.

Examine / interview / test

Examine remote-access policy, posture-interface agreements, and exception approvals. Interview identity and external endpoint leads about failure behavior. Test four posture states and an administrative session from an unapproved context in an isolated tenant test environment.

Acceptance criterion

Approved compliant sessions succeed only with required authentication; noncompliant, unknown, stale, and unapproved administrative contexts are denied. An unsupported policy feature or unverified external dependency leaves the criterion unresolved, not passed.

Evidence: FS-EV-005, FS-EV-006, FS-EV-007, FS-EV-015

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AC-20 | Use of External Systems

Assessment status: Illustrative; not assessed

Allocation: Shared: customer mission/data owner; tenant access/sharing operators; candidate provider external-access controls.

The notional data owner would approve each external collaboration relationship before the operator enables a guest invitation, external meeting path, or document exchange. Approval would specify recipient eligibility, information purpose, permitted actions, endpoint expectations, and termination conditions. Microsoft would provide candidate restriction mechanisms but would not authorize another organization's system for the customer's mission. External endpoint and recipient-system protections remain separately governed and cannot be inferred from tenant authentication. The operator would test denied access after expiry and record restrictions when recipient assurance is absent. The fictional missing-expiry exception demonstrates an unresolved governance condition, not an actual exposure in Navy or Microsoft systems. No real external connection is established by this fixture.

Notional organization-defined parameters

Notional population: 20 guest-collaboration exceptions; weekly review of all 20; maximum 30-day exception; unapproved external systems and anonymous access prohibited.

Examine / interview / test

Examine all exception approvals and the external-system conditions for each relationship. Interview the mission owner and endpoint liaison. Test a permitted recipient, an unapproved recipient, an expired recipient, and an unmanaged-device case against documented policy.

Acceptance criterion

Every enabled external relationship has an approved purpose, eligible recipient, bounded duration, and applicable external-system conditions; every negative access test is denied. Missing expiry, sponsor, or recipient assurance fails the sampled relationship.

Evidence: FS-EV-006, FS-EV-008, FS-EV-015

Known modeled gaps: FS-FIND-002

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AT-2 | Literacy Training and Awareness

Assessment status: Illustrative; not assessed

Allocation: Shared: customer training and mission authorities; tenant operator for service-specific guidance; provider for candidate service notices.

The notional security manager would provide tenant-specific awareness covering safe sharing, suspicious sign-in reporting, meeting admission, records obligations, and the support-channel boundary. Workforce users would learn that a familiar collaboration interface does not grant authority to release information or upload sensitive content to support. Administrators would receive an additional briefing on separate identities, evidence minimization, and emergency change review. Microsoft may provide service guidance, but customer training completion and comprehension remain customer responsibilities rather than inherited controls. Command training records would be reconciled against tenant access eligibility. Only invented exercise content would appear in training tests. No attendance records, completion rates, or actual user behavior have been supplied.

Notional organization-defined parameters

Notional targets: initial briefing before access; annual refresher; administrator briefing before role grant; sample 30 workforce training records and all 12 privileged-assignment training records.

Examine / interview / test

Examine course content and completion-to-access reconciliation for 42 sampled assignment/account records. Interview five users and two administrators. Test comprehension with four synthetic scenarios covering expired links, suspicious access, hold instructions, and support redaction.

Acceptance criterion

Every sampled access grant has current required training; all interviewed administrators identify emergency/reporting procedures; each participant correctly resolves all four safety-critical scenarios or is retrained before unrestricted access.

Evidence: FS-EV-007, FS-EV-013

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AU-2 | Event Logging

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant SOC for event selection and reconciliation; provider for supported tenant-visible events; customer for external systems.

The notional SOC would define required event categories before configuring collection and would reconcile them against actual DoD workload availability. Identity sign-ins, privileged changes, mailbox administration, SharePoint sharing, OneDrive sharing, Teams policy changes, access-policy decisions, and tenant configuration changes form the proposed source set. Microsoft would generate only documented service events; the operator cannot assume access to provider internal telemetry or commercial-cloud audit features. Customer endpoint events remain outside this boundary and require a separate handoff. Each source would have an owner, collection method, expected latency, and evidence of test-event receipt. The invented audit sample omits Teams coverage, so source completeness is explicitly unresolved.

Notional organization-defined parameters

Notional targets: 8 required source categories; daily presence check; one safe test event per category monthly; ingestion delay target at most 24 hours unless a verified source-specific limit is approved.

Examine / interview / test

Examine the eight-source matrix and configured collection paths. Interview SOC and workload leads about unsupported event classes. Test one safe representative event for each source, recording event time, receipt time, and retrieval query.

Acceptance criterion

All 8 sources have verified availability, ownership, and a retrievable test event within the approved delay; absent or unsupported sources remain explicit gaps. Seven of eight sources does not meet the criterion.

Evidence: FS-EV-001, FS-EV-009

Known modeled gaps: FS-FIND-003

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AU-3 | Content of Audit Records

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for supported source fields; tenant SOC for completeness checks; customer privacy owner for minimization.

The notional SOC would define a normalized investigation record containing source, event and ingestion times, actor, operation, target, outcome, and correlation information. Normalization would retain original field provenance and distinguish unavailable values from empty strings or invented defaults. Microsoft would determine the supported service-event schema, while the operator would document mapping differences and assess whether each source supports the investigation purpose. Customer privacy owners would approve minimized identifiers and handling rules for exported records. The sample uses aliases and fabricated events only, not real user identifiers. A complete identity event would not establish Teams coverage or field completeness. Missing sources and missing required fields would be reported separately.

Notional organization-defined parameters

Notional sample: 5 events from each of 8 source categories, 40 total; require 8 investigation fields or an explicitly documented source-specific equivalent; preserve timezone and original event meaning.

Examine / interview / test

Examine raw-to-normalized mappings and 40 representative records. Interview SOC and privacy coordinators about ambiguous actor/target values. Test reconstruction of who did what to which object and when, including one failed action and one delayed-ingestion event per available source.

Acceptance criterion

Every sampled record permits unambiguous event reconstruction with approved identifiers and timestamps; no required field is fabricated; all eight sources are represented. Missing source coverage or unexplained field loss fails the affected sample.

Evidence: FS-EV-001, FS-EV-009, FS-EV-013

Known modeled gaps: FS-FIND-003

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AU-6 | Audit Record Review, Analysis, and Reporting

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant SOC for review and reporting; provider for available telemetry/advisories; customer mission and incident authorities.

The notional SOC would review administrative grants, suspicious access decisions, sharing-policy changes, and unexpected forwarding in a daily queue. High-priority events would receive expedited triage after ingestion, with the record explicitly separating service collection delay from analyst response time. Microsoft would supply available event data and applicable service advisories; optional Defender or advanced analytics functions require cloud and SKU verification and are not assumed. The customer would decide mission impact and coordinate external endpoint or network investigation. Analysts would document benign explanations, containment requests, and escalation recipients rather than merely marking alerts reviewed. The fabricated audit sample illustrates a queue handoff but does not demonstrate actual detection or analyst performance.

Notional organization-defined parameters

Notional targets: daily queue review; high-priority triage within 30 minutes of ingestion; weekly trend review; sample 10 dispositions including 3 high-priority administrative/sharing scenarios.

Examine / interview / test

Examine queue timestamps and ten disposition records. Interview duty analysts and mission incident contacts. Test three inert injected scenarios for a privileged grant, prohibited sharing change, and repeated denied access, including routing when one source is unavailable.

Acceptance criterion

All three high-priority test scenarios reach an accountable analyst within 30 minutes of ingestion and have documented rationale and escalation; all ten dispositions are traceable. Unavailable source coverage prevents an overall detection-coverage conclusion.

Evidence: FS-EV-001, FS-EV-009, FS-EV-012

Known modeled gaps: FS-FIND-003

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AU-9 | Protection of Audit Information

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant SOC/identity operators for access; provider for candidate service protection; external repository owner for exported copies.

The notional operator would separate audit review from tenant policy administration and limit export and retention changes to approved custodians. Evidence copies would include collection time, source, collector, integrity digest, and custody transfers without embedding secrets or operational content. Microsoft would provide candidate protections for service-held records, but immutable storage or customer-visible tamper guarantees cannot be assumed without current evidence. Any external evidence repository remains outside this boundary and requires its own authorization and access review. Customer privacy and incident authorities would approve disclosure. The included audit text is a synthetic sample, not an integrity-protected production log. Protection would require permission tests and retrieval evidence beyond configuration intentions.

Notional organization-defined parameters

Notional targets: 2 named audit custodians; quarterly audit-access review; independent approval for retention/export configuration changes; digest and custody entry for every collected evidence batch.

Examine / interview / test

Examine audit roles, custody records, and export destination approvals. Interview the SOC lead and external repository owner. Test that an ordinary workload administrator cannot alter protected evidence and that an authorized custodian can retrieve and verify a controlled test batch.

Acceptance criterion

Unauthorized alteration/export attempts are denied, authorized retrieval preserves recorded digests, and every sampled transfer has an accountable custodian and approved destination. Provider or repository protection not evidenced remains unresolved.

Evidence: FS-EV-001, FS-EV-005, FS-EV-007, FS-EV-009

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

AU-11 | Audit Record Retention

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant SOC and records officer; provider for supported service retention; external repository owner if separately approved.

The notional SOC and records officer would agree on audit retention separately from business-content schedules and legal-hold requirements. The proposed searchable and protected-retention periods would be checked against actual service licensing, available exports, and separately approved storage before adoption. Microsoft would document candidate service retention limits; the operator would demonstrate uninterrupted collection and retrieval rather than presume an advanced audit feature exists. Customer records authorities retain schedule and disposition decisions. A hold affecting incident records would suspend conflicting disposal until authorized release. The missing source inventory and fictional hold conflict prevent a complete retention conclusion. Neither one year of audit retention nor content preservation is evidence of general workload backup.

Notional organization-defined parameters

Notional targets: 90 days searchable audit, 365 days protected retention; monthly retrieval at days 1, 30, and 90 and archive day 365 where such history exists; no disposal during an applicable hold.

Examine / interview / test

Examine licensed retention limits, export coverage, schedules, and hold instructions. Interview SOC and records owners. Test retrieval across approved age boundaries and a controlled held-record disposition attempt; use historical evidence rather than inventing elapsed retention.

Acceptance criterion

All required sources are retrievable for the approved periods, applicable holds prevent disposition, and age-boundary evidence is genuine. Insufficient history, missing sources, or conflicting hold rules yields unresolved/fail, not a simulated pass.

Evidence: FS-EV-001, FS-EV-009, FS-EV-010

Known modeled gaps: FS-FIND-003, FS-FIND-006

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CA-2 | Control Assessments

Assessment status: Illustrative; not assessed

Allocation: Shared: independent customer assessor and security manager; provider for authorized service evidence; AO separately designated.

The notional assessment coordinator would prepare an approved plan identifying the forty representative controls, inherited candidates, retained customer duties, sampling populations, and test restrictions. Examine, interview, and test results would be linked to evidence and distinguish design adequacy from operational performance. Microsoft service protections would require an authorized evidence package, not a public compliance page or this narrative. The customer would supply tenant exports, personnel approvals, interface agreements, and independent testers. Samples included here are invented exercises and cannot establish control satisfaction. Six fictional open findings are deliberately retained for workflow testing. An actual assessment would require a complete applicable baseline and independence review before conclusions could support an authorization decision.

Notional organization-defined parameters

Notional scope: 40 representative controls and 6 open scenario findings; independent review of every proposed finding closure; annual assessment planning plus reassessment after material boundary change.

Examine / interview / test

Examine the assessment plan, evidence provenance, full baseline mapping, and assessor independence. Interview owner and assessor about inherited duties. Test reproducibility of one selected procedure from each of access, audit, sharing, and recovery using authorized inert artifacts.

Acceptance criterion

Every assessment conclusion cites valid evidence, actual procedure results, responsible ownership, and applicable scope; all six closures require independent retest. Synthetic samples, missing baseline coverage, or unsigned decisions cannot support a passed authorization gate.

Evidence: FS-EV-005, FS-EV-014, FS-EV-016

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CA-3 | Information Exchange

Assessment status: Illustrative; not assessed

Allocation: Shared: customer exchange authorities and mission owners; tenant operator for local restrictions; provider for service interfaces.

The notional operator would document each external information exchange with a purpose, information category, partner authority, transport assumptions, and conditions for suspension. The flow register includes identity federation, endpoint posture, external recipients, security evidence export, and sanitized support coordination. Microsoft would provide candidate service interfaces, but customer exchange approvals are not inherited from the provider. Recipient systems, external repositories, and support service remain outside the proposed tenant boundary. Customer mission owners would authorize release and require reciprocal responsibilities where appropriate. Internal workload flows would also be recorded to expose permission and records dependencies. The fictional guest exception lacks expiry, and formal exchange approvals are absent, so no connection is represented as authorized.

Notional organization-defined parameters

Notional register: 10 flows, each reviewed annually and after material change; external exchange approval required before enablement; guest-related approvals expire within 30 days unless renewed.

Examine / interview / test

Examine all ten flow records and external agreements for purpose, parties, protection, and termination. Interview mission, identity, endpoint, and provider liaisons. Test suspension of one guest exchange and one evidence-export path using inert content and approved nonproduction interfaces.

Acceptance criterion

Every enabled external exchange has current approval and documented responsibilities; both suspension tests prevent further unauthorized transfer; support data is minimized and separately approved. Missing approval or expiry fails the applicable exchange.

Evidence: FS-EV-008, FS-EV-015

Known modeled gaps: FS-FIND-002

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CA-7 | Continuous Monitoring

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant security manager and monitoring owners; customer risk authorities; provider for candidate service-change and assurance inputs.

The notional security manager would maintain a monitoring calendar connecting each activity to a source, threshold, accountable owner, and escalation deadline. Daily audit checks, weekly sharing review, monthly privilege and baseline review, and quarterly restoration exercises would feed a single risk register. Microsoft service advisories and authorized assurance updates would be inputs, not substitutes for tenant monitoring. Customer mission owners would assess impact and retain risk decisions for endpoints, networks, and data use. The operator would record missed activities as gaps instead of reporting a green dashboard from absent evidence. Six open fictional findings remain visible until independent closure review. Monitoring does not make the unsigned decision effective or imply ongoing authorization.

Notional organization-defined parameters

Notional cadence: daily, weekly, monthly, quarterly, and annual activities as listed; monthly owner risk review; missed high-priority activity escalated within 1 business day; all 6 POAMs reviewed weekly.

Examine / interview / test

Examine the monitoring calendar, thresholds, and six POAM status histories. Interview activity owners and the system owner. Test a missed audit source, expired exception, and overdue milestone to confirm routing and visible unresolved status.

Acceptance criterion

Every activity has evidence or an explicit missed/unavailable state; each injected threshold breach reaches its owner within the stated deadline; no open finding is automatically marked closed and no monitoring result activates the draft decision.

Evidence: FS-EV-001, FS-EV-006, FS-EV-009, FS-EV-011, FS-EV-016

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CM-2 | Baseline Configuration

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant change board and workload leads; provider for service defaults and changes; customer mission/privacy authorities.

The notional change board would maintain a versioned baseline covering tenant identity, administrative roles, messaging, document sharing, Teams policies, audit sources, and records dependencies. Each setting would identify its intended value, available enforcement mechanism, approving owner, and exception condition. Microsoft would document supported service settings and changes, while the customer operator selects and validates tenant values. Provider-managed infrastructure settings are candidate inherited items, not tenant-configurable baseline entries. Customer mission and privacy owners would approve local impacts and external dependencies. The baseline would distinguish unavailable optional features from disabled supported features. The synthetic change worksheet demonstrates format only; no actual export or approved baseline has been supplied.

Notional organization-defined parameters

Notional baseline: 12 logical components and 24 capabilities; monthly reconciliation; version increment for each approved policy revision; rollback reference and owner required for every changed setting.

Examine / interview / test

Examine baseline versions, settings exports, and service-availability checks. Interview the change chair and two workload leads. Test comparison of an approved baseline with a controlled changed setting and verify that unsupported product assumptions are flagged.

Acceptance criterion

Every component has an owned, approved, reproducible baseline; all observed deviations have approved exceptions or tracked corrective actions; no nonexistent/unverified feature is credited as an enforced setting.

Evidence: FS-EV-003, FS-EV-006, FS-EV-015

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CM-3 | Configuration Change Control

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant change board and implementers; customer records/data owners; provider for underlying service changes.

The notional change chair would require a request describing purpose, affected workloads, before-and-after settings, security and privacy impact, testing, and rollback. A reviewer independent of the implementer would authorize tenant policy changes before execution. Microsoft retains its underlying service-change processes; the customer board evaluates communicated effects but does not control provider infrastructure deployments. Customer records and mission owners would approve changes affecting retention, holds, or external sharing. Emergency changes would be time bounded and reviewed the next business day. The invented change sample contains a blocked retention proposal with an unresolved hold conflict. It is not evidence of a production rollout, successful rollback, or approved exception.

Notional organization-defined parameters

Notional sample: 8 policy changes, including 2 emergency cases; independent approval for 100%; emergency retrospective within 1 business day; no retention change promoted with unresolved hold conflict.

Examine / interview / test

Examine eight change records and their impact/approval/rollback evidence. Interview the change chair, implementer, and records officer. Test rejection of an unapproved change and a conflicting retention proposal, then rehearse rollback of an inert nonproduction sharing setting.

Acceptance criterion

All eight changes have independent approval or timely emergency review, verifiable results, and rollback criteria; the hold-conflicting proposal remains blocked. Missing review, untested rollback, or promotion despite conflict fails.

Evidence: FS-EV-003, FS-EV-006, FS-EV-010

Known modeled gaps: FS-FIND-006

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CM-6 | Configuration Settings

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant workload and identity operators; provider for supported setting semantics; customer risk owner for exceptions.

The notional operator would specify restrictive settings for automatic forwarding, anonymous links, guest admission, administrative roles, and access-policy failure behavior. Values would be justified against mission need and verified against the actual DoD service, license, and supported policy interface before enforcement is claimed. Microsoft would define available settings and their semantics; the tenant operator would configure them and test resulting behavior. Customer data owners retain exception decisions and cannot delegate them to a default product setting. Monthly comparisons would identify drift and distinguish planned service changes from unauthorized edits. Optional Purview, Defender, or privileged-management settings would remain conditional. No configuration export has been supplied to demonstrate current values.

Notional organization-defined parameters

Notional targets: anonymous links disabled; unapproved external forwarding denied; unknown posture denied; configuration drift triaged within 2 business days; 15 security-relevant settings sampled monthly.

Examine / interview / test

Examine fifteen baseline settings, observed values, and exception approvals. Interview workload and identity leads about policy interactions. Test five denied operations and one intentional nonproduction drift condition, including alert and rollback routing.

Acceptance criterion

All fifteen observed values match approved settings or current exceptions, all five prohibited operations are denied, and drift is assigned within two business days. Unsupported policy features cannot satisfy an enforcement test.

Evidence: FS-EV-003, FS-EV-006, FS-EV-014

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CM-8 | System Component Inventory

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant inventory custodian; provider for service-scope documentation; customer owners for external dependencies.

The notional inventory custodian would maintain twelve logical service and operational components, each with an owner, two named capabilities, responsibility boundaries, and evidence dependencies. Tenant configuration objects and approved interfaces would be traced to these entries without inventing virtual machines, Azure subscriptions, or physical appliances. Microsoft would maintain its own underlying service inventory and supply relevant boundary evidence; that inventory is not reproduced as customer assets. Customer endpoint, network, federation, and recipient-system owners would maintain separate inventories and identify their interfaces. Monthly reconciliation would compare tenant workload enablement and policy ownership with the scope statement. These entries are synthetic design records only, not discovered or verified deployed components.

Notional organization-defined parameters

Notional inventory: exactly 12 logical components and 24 named capabilities; every entry has an owner and responsibility split; monthly reconciliation and update within 5 business days of approved scope change.

Examine / interview / test

Examine all twelve entries, their capabilities, and service/interface scope records. Interview the inventory custodian and external endpoint liaison. Test tracing three enabled workload settings and two external interfaces to correct owners without incorporating external assets into the tenant inventory.

Acceptance criterion

All twelve entries and twenty-four capabilities reconcile without duplicates or orphaned owners; every sampled setting/interface maps to the correct boundary; no IaaS or endpoint platform is mislabeled as a native tenant component.

Evidence: FS-EV-005, FS-EV-006, FS-EV-015

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CP-2 | Contingency Plan

Assessment status: Illustrative; not assessed

Allocation: Shared: customer continuity and mission owners; tenant workload operators; provider for candidate service continuity.

The notional continuity coordinator would document mission priorities, outage communications, service dependencies, tenant recovery actions, and separately approved alternate collaboration arrangements. The plan would distinguish provider service restoration from customer recovery of content, permissions, ownership, and cross-workload references. Microsoft would supply candidate service continuity commitments and limitations through verified channels, not a blanket promise derived from IL5 documentation. Customer mission owners retain recovery objectives and authorization of external alternatives. Tenant operators would determine whether actual recovery mechanisms can meet those objectives and escalate unsupported cases. The included recovery worksheet is fictional and incomplete. No outage exercise, provider commitment, or mission acceptance has been supplied.

Notional organization-defined parameters

Notional targets: first mission notice within 30 minutes; priority collaboration recovery within 24 hours; priority content loss no more than 24 hours where verified mechanisms support it; annual plan review.

Examine / interview / test

Examine the plan, dependency map, provider limitations, and approved alternate arrangements. Interview continuity, workload, and mission owners. Test an outage tabletop with unavailable Teams and linked SharePoint content, recording decision and communication timestamps.

Acceptance criterion

Every priority function has an owner, supported recovery path, communication route, and approved alternative or explicit unresolved gap; the tabletop reaches mission contacts within 30 minutes. Unsupported 24-hour targets cannot be reported as achieved.

Evidence: FS-EV-004, FS-EV-005, FS-EV-011, FS-EV-015

Known modeled gaps: FS-FIND-004

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CP-4 | Contingency Plan Testing

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant continuity coordinator and independent tester; customer data owners; provider for documented recovery support.

The notional continuity coordinator would run quarterly isolated exercises covering a mailbox item, site files and permissions, OneDrive departure handoff, and Teams membership with linked content. Each exercise would record prerequisites, expected results, actual timing, unsupported objects, and data-owner reconciliation. Microsoft would provide documented service mechanisms and support limits, while the customer executes and evaluates tenant recovery actions. External identity and network continuity would be coordinated with their separate owners. Retention or version history would be used only where verified to support the specific test, never as a universal backup claim. The supplied worksheet invents one mailbox result and leaves other cases incomplete; it is not a real exercise report.

Notional organization-defined parameters

Notional cadence: quarterly; 4 workload classes; at least 3 inert objects per workload; independent observer and data-owner reconciliation required; improvement plan within 10 business days.

Examine / interview / test

Examine exercise plans, source-object manifests, timings, and reconciliation records. Interview continuity and workload leads. Test all four workload classes in an authorized isolated environment, including one intentionally unsupported recovery case and communication fallback.

Acceptance criterion

All twelve minimum test objects are reconciled for content and required metadata/permissions, all four workload classes are exercised, timing is measured, and unsupported cases have approved treatment. The fictional partial worksheet does not pass.

Evidence: FS-EV-004, FS-EV-011, FS-EV-016

Known modeled gaps: FS-FIND-004

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CP-9 | System Backup

Assessment status: Illustrative; not assessed

Allocation: Shared: customer continuity/data owners for recoverability needs; tenant operators for supported recovery sources; provider for documented service mechanisms.

The notional operator would identify which workload objects require recoverable copies, which service mechanisms actually preserve them, and which gaps need a separately authorized solution. Configuration exports, content recovery sources, permissions, and ownership metadata would be evaluated separately. Microsoft would describe candidate service preservation and recovery behavior; customer expectations cannot be inferred from retention, recycle bins, version history, or legal holds alone. Customer mission and records owners retain recovery requirements and disposition authority. Third-party backup is outside this fixture and cannot silently fill a gap. The recovery-source register would record protection, age, access, and testability. No actual backup inventory or comprehensive restore evidence is supplied.

Notional organization-defined parameters

Notional target: recoverable priority content age at most 24 hours where supported; weekly tenant-configuration export review; monthly recovery-source inventory; 3 content objects plus permission/ownership metadata checked per workload.

Examine / interview / test

Examine workload recovery-source inventories, age/protection evidence, and retention/hold dependencies. Interview mission and continuity owners. Test retrieval of three objects and required permissions/ownership metadata for each workload from a verified recoverable source.

Acceptance criterion

Every priority object class has an evidenced protected recovery source meeting the approved age target and a successful reconciled retrieval; missing permissions, unsupported object types, or reliance solely on retention claims leaves the requirement unmet.

Evidence: FS-EV-004, FS-EV-005, FS-EV-010, FS-EV-011

Known modeled gaps: FS-FIND-004

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

CP-10 | System Recovery and Reconstitution

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant continuity/workload operators; customer mission/data owners; provider for underlying service restoration.

The notional operator would reconstitute tenant collaboration only after verifying content integrity, permissions, ownership, audit visibility, and linked-workload references. A provider service-health recovery notice would be an input, not sufficient proof that customer mission state is restored. Microsoft would restore underlying service functions under its verified arrangements; tenant operators would perform available customer recovery actions and document unrecoverable states. Customer data owners would reconcile restored objects and approve resumption of mission use. External endpoint and identity dependencies would remain separately validated. The invented worksheet does not establish recovery timing or integrity for all workloads. Any unmet objective would remain a tracked gap rather than an assumed successful restoration.

Notional organization-defined parameters

Notional targets: priority collaboration reconstitution within 24 hours where supported; verify 3 objects per workload plus permissions and ownership; mission-owner signoff required before closing an actual recovery incident.

Examine / interview / test

Examine recovery runbooks, before/after manifests, and acceptance records. Interview continuity and mission owners. Test restore and reconstitution for mailbox, site, OneDrive, and Teams-linked artifacts, including revoked-user denial and audit generation after recovery.

Acceptance criterion

All required objects, permissions, owners, and links reconcile; revoked users remain denied; audit events remain available; measured recovery meets the approved objective or an explicit risk decision is documented. No fictional sample can establish completion.

Evidence: FS-EV-004, FS-EV-011, FS-EV-012

Known modeled gaps: FS-FIND-004

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

IA-2 | Identification and Authentication (Organizational Users)

Assessment status: Illustrative; not assessed

Allocation: Shared: tenant identity operator; external customer identity issuer; provider for supported authentication mechanisms.

The notional identity lead would require a unique workforce identity and approved strong authentication for each interactive organizational user. Administrative access would use a separate identity with an explicitly approved authentication path and role grant. Microsoft would supply candidate service-side identity validation mechanisms, but the exact government federation and authentication integration must be verified rather than assumed. External customer authorities retain identity proofing, credential issuance, eligibility, and revocation responsibilities. The operator would test rejected credentials and revoked identities without recording secrets. Shared user accounts would not substitute for individual accountability. The access sample highlights missing administrative review evidence; neither that worksheet nor public service documentation establishes authentication deployment or effectiveness.

Notional organization-defined parameters

Notional targets: unique identities for all 2,400 workforce accounts; strong authentication on all interactive sessions; test 10 ordinary and all 12 privileged assignments; no shared interactive workforce identities.

Examine / interview / test

Examine identity uniqueness, authentication policy, federation trust, and administrative assignment approvals. Interview identity issuer liaison and tenant lead. Test valid, missing-factor, revoked, and mismatched-identity sign-ins with nonproduction identities and no credential disclosure.

Acceptance criterion

Every sampled identity is uniquely attributable and approved; all invalid/revoked or insufficient-authentication tests are denied; separate privileged identity and current approval are evidenced. Missing review or unsupported authentication assumptions remain unresolved.

Evidence: FS-EV-002, FS-EV-005, FS-EV-006, FS-EV-007

Known modeled gaps: FS-FIND-001

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

IA-5 | Authenticator Management

Assessment status: Illustrative; not assessed

Allocation: Shared: customer authenticator issuer and custodians; tenant identity operator; provider for supported revocation/session behavior.

The notional operator would document the lifecycle of approved authenticators, including enrollment authorization, compromise reporting, replacement, revocation, and emergency access custody. The fixture intentionally contains no passwords, private keys, recovery codes, or real certificate identifiers. Microsoft would provide candidate service handling for supported authentication methods and session invalidation, while external customer issuers retain credential proofing and issuance duties. Tenant administrators would coordinate revocation and test residual access rather than assume issuer revocation instantly terminates every session. Emergency authenticators would require two custodians and a documented retrieval process. Optional privileged-management tooling is not presumed available. No authenticator inventory or revocation test evidence has been supplied.

Notional organization-defined parameters

Notional targets: suspected compromise reported immediately; tenant revocation actions initiated within 15 minutes of validated notice; quarterly emergency-custody review; test 4 authenticator lifecycle scenarios without storing secrets.

Examine / interview / test

Examine enrollment/replacement approvals, revocation workflow, and emergency custody records. Interview issuer liaison and two custodians. Test lost-authenticator, compromised-identity, replacement, and emergency-use scenarios, measuring session behavior through supported mechanisms.

Acceptance criterion

Every lifecycle action is authorized and attributable; revocation actions begin within 15 minutes; residual-session behavior is documented and treated; emergency use notifies independent reviewers. Secret material must not appear in test evidence.

Evidence: FS-EV-005, FS-EV-007, FS-EV-012

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

IR-4 | Incident Handling

Assessment status: Illustrative; not assessed

Allocation: Shared: customer incident authority and tenant SOC; provider for service incidents; external endpoint/network owners.

The notional SOC would handle suspected account compromise or unauthorized sharing through preparation, triage, containment, investigation, recovery, and lessons learned. Tenant actions could include restricting an identity, revoking a sharing exception, preserving available audit records, and coordinating workload validation. Microsoft would handle underlying service incidents and provide applicable communications, while customer incident authorities decide mission impact and reporting. Endpoint and network investigation remains outside this boundary and is handed to the external computing authority. Support escalation would contain only approved sanitized details because support is outside the service accreditation boundary. The included event sample illustrates a fictional alert, not an actual compromise, successful containment, or provider incident.

Notional organization-defined parameters

Notional targets: high-priority triage within 30 minutes of ingestion; containment decision within 60 minutes of validated incident; custody record for all preserved evidence; lessons learned within 10 business days of actual closure.

Examine / interview / test

Examine the incident runbook, containment authority, and custody templates. Interview SOC, identity, and external endpoint leads. Test an inert compromised-administrator/sharing tabletop through containment, evidence preservation, external handoff, and recovery authorization.

Acceptance criterion

The tabletop assigns authority, reaches the triage/decision targets, preserves traceable evidence, and obtains mission recovery approval; no sensitive support export or unsupported containment action occurs. Actual response capability requires operational evidence.

Evidence: FS-EV-001, FS-EV-007, FS-EV-012, FS-EV-015

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

IR-6 | Incident Reporting

Assessment status: Illustrative; not assessed

Allocation: Shared: customer reporting authority and tenant SOC; provider for its service notices; mission owner for impact statements.

The notional SOC would maintain a reporting matrix identifying internal security, mission, privacy, records, and provider liaison recipients for different incident categories. Initial reports would distinguish confirmed facts from hypotheses and identify affected workloads without unnecessary content or personal data. Microsoft service notifications would be reconciled with customer observations, not treated as a substitute for required customer reporting. Actual DoD reporting authorities and deadlines must be determined by the customer; the timing below is only an exercise target. Support communication remains a separately reviewed external exchange. The operator would track acknowledgement and escalation when contacts are unreachable. No report has been sent, and all listed addresses use the reserved example.test domain.

Notional organization-defined parameters

Notional exercise targets: notify internal incident authority within 1 hour of validation; mission update every 4 hours during active response; contact-list review monthly; customer-mandated regulatory reporting deadlines remain to be established.

Examine / interview / test

Examine the reporting matrix, mandatory-authority analysis, and redaction checklist. Interview SOC and mission contacts. Test a simulated initial report, an unreachable-contact escalation, and a sanitized provider-support draft without transmitting anything externally.

Acceptance criterion

The exercise routes accurate minimized reports within the 1-hour target and reaches a backup contact; actual required authorities/deadlines are documented before operational use. An unverified regulatory deadline or unapproved support disclosure fails readiness.

Evidence: FS-EV-012, FS-EV-013, FS-EV-015

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

MA-2 | Controlled Maintenance

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for underlying SaaS maintenance; tenant operator for advisory/change coordination; customer for external endpoint maintenance.

The notional provider assurance liaison would request evidence describing maintenance authorization, scheduling, oversight, and protection for infrastructure supporting the relevant DoD services. Microsoft would retain underlying SaaS maintenance responsibilities; tenant administrators would not perform physical maintenance or claim control over provider infrastructure. The operator would review service advisories, assess mission impact, and coordinate customer-visible configuration changes through the tenant change process. Customer endpoint and network maintenance remains separately owned outside this boundary. The operator would avoid collecting unnecessary operational content in support cases and verify any required customer action. Because provider maintenance and authorization evidence is absent, this control is only a candidate inherited area and cannot be credited as satisfied.

Notional organization-defined parameters

Notional targets: review relevant service advisories each business day; record tenant impact within 2 business days; review provider maintenance assurance annually and upon material service-boundary change; sample 3 advisory/change cases.

Examine / interview / test

Examine authorized provider maintenance assurance and three tenant advisory responses. Interview provider liaison and change chair. Test an advisory tabletop requiring a tenant action, verifying approval, mission notification, and separation from external endpoint maintenance.

Acceptance criterion

Current applicable provider evidence identifies maintenance responsibilities and oversight; all three tenant cases have timely impact review and authorized changes. Without provider assurance, inheritance remains unresolved regardless of tabletop success.

Evidence: FS-EV-003, FS-EV-005, FS-EV-014

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

MP-6 | Media Sanitization

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for physical service media; tenant records/workload operators for logical disposition; customer for endpoint/export media.

The notional records officer would authorize tenant content disposition only after checking applicable schedules, preservation instructions, and privacy obligations. Logical deletion would be recorded separately from provider physical media sanitization, and neither would be inferred solely from an item disappearing from a user interface. Microsoft would supply candidate evidence for service media handling and sanitization within its actual boundary. Customer endpoint disks and exported evidence media remain outside this tenant scope under their own sanitization procedures. Operators would document service deletion delays and recoverability limits instead of promising immediate irreversible erasure. The fictional retention/hold conflict blocks disposition readiness. No real content was deleted and no media sanitization certificate is supplied.

Notional organization-defined parameters

Notional targets: records/counsel clearance before every held-content disposition; monthly disposition review; sample 5 eligible and 5 held synthetic objects; provider media-sanitization assurance reviewed annually.

Examine / interview / test

Examine schedule authority, hold release, deletion behavior, and provider sanitization evidence. Interview records and provider liaisons. Test that five held objects resist unauthorized disposition and that five eligible inert objects follow the approved documented deletion lifecycle.

Acceptance criterion

No held object is disposed without release, each eligible deletion follows approved timing, and physical-media claims are supported by applicable provider evidence. The hold conflict or absent media evidence prevents a satisfied conclusion.

Evidence: FS-EV-003, FS-EV-005, FS-EV-010

Known modeled gaps: FS-FIND-006

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

PE-3 | Physical Access Control

Assessment status: Illustrative; not assessed

Allocation: Shared allocation: candidate provider data-center physical controls; customer facilities for external user/administrator locations; tenant liaison for inheritance verification.

The notional tenant operator would not list a customer-controlled data center or invent physical safeguards for Microsoft facilities. Instead, the provider assurance liaison would obtain current authorized evidence identifying the applicable service facilities boundary and physical-access responsibilities. Microsoft would be the candidate owner of physical controls for its underlying SaaS infrastructure. Customer facilities authorities retain physical protection of administrator work areas, endpoint devices, and customer network equipment outside this boundary. The tenant operator would document these allocations and verify that no omitted facility dependency is silently inherited. Public IL5 service descriptions do not establish facility-level control performance. Provider physical-access evidence is not supplied, so inheritance and applicability remain unverified.

Notional organization-defined parameters

Notional targets: annual provider-boundary assurance review; reassessment after material service-scope change; trace all 4 collaboration workloads to applicable provider scope and all external facility duties to a customer owner.

Examine / interview / test

Examine authorized service-boundary and physical-control evidence plus customer responsibility mapping. Interview provider liaison and customer facilities representative. Test a desk-based trace of Exchange, SharePoint, OneDrive, and Teams to applicable evidence and external facility exclusions; do not test provider facilities.

Acceptance criterion

Each workload's physical-control inheritance is supported by current applicable authorized evidence, and every external facility responsibility has an owner. Public documentation or a completed mapping alone cannot establish physical-control effectiveness.

Evidence: FS-EV-005, FS-EV-015, FS-EV-016

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

PL-2 | System Security and Privacy Plans

Assessment status: Illustrative; not assessed

Allocation: Shared: customer system owner, security manager, and privacy officer; provider for applicable shared-responsibility inputs.

The notional security manager would maintain a plan describing mission, categorization assumptions, boundary, information types, roles, dependencies, and control allocations. The plan would clearly separate the tenant operator, customer mission authorities, and candidate provider duties rather than label every SaaS control inherited. Microsoft documentation would supply public context, while current service authorization and customer-responsibility evidence would be requested separately. Customer privacy authorities would determine processing authority and handling requirements before operational personal information is introduced. All optional products and external interfaces would be explicitly qualified. This fixture contains forty representative narratives, not a complete approved baseline or actual SSP. Its draft decision remains unsigned and ineffective regardless of document completeness.

Notional organization-defined parameters

Notional targets: annual plan review and review within 10 business days of material boundary change; all 12 components, 24 capabilities, 10 flows, and 40 representative controls cross-referenced; complete operational baseline still required.

Examine / interview / test

Examine plan scope, categorization rationale, privacy analysis, and control ownership. Interview system owner, security manager, and privacy officer. Test tracing three mission uses to data flows, components, controls, evidence status, and residual-risk decisions.

Acceptance criterion

All sampled traces resolve without boundary or ownership contradictions, privacy/categorization approvals are supplied for operational use, and the full applicable baseline is addressed. This synthetic subset and unsigned decision cannot count as an approved plan or authorization.

Evidence: FS-EV-005, FS-EV-013, FS-EV-015, FS-EV-016

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

PS-4 | Personnel Termination

Assessment status: Illustrative; not assessed

Allocation: Shared: customer personnel and mission authorities; tenant identity/workload operators; provider for supported account/session actions.

The notional identity lead would act on an authoritative personnel notice to restrict sign-in, remove administrative assignments, revoke sharing sponsorship, and coordinate active-session handling. The workload lead would separately preserve or transfer mailbox and OneDrive content according to records and mission instructions. Microsoft would supply supported service account and session mechanisms, but personnel decisions and content ownership remain customer responsibilities. External identity issuers would revoke their credentials under a separate process and confirm the handoff. Operators would not equate account deletion with successful access revocation or permission to destroy records. The synthetic access worksheet includes an invented departure case only. No actual personnel record, session-revocation result, or completed content handoff is supplied.

Notional organization-defined parameters

Notional targets: restrict tenant access within 4 hours of authoritative notice; remove privileged assignments in the same window; data-owner handoff decision within 1 business day; sample 5 departure cases monthly.

Examine / interview / test

Examine five departure notices, access-action timestamps, role removals, and preservation instructions. Interview personnel, identity, and records contacts. Test one nonproduction departure across sign-in, delegated mailbox, shared file, Teams membership, and residual-session behavior.

Acceptance criterion

All five sampled access restrictions meet the 4-hour target; the test identity loses unauthorized access across all paths; retained content follows documented hold/ownership instructions. Missing notice authority or residual unauthorized access fails.

Evidence: FS-EV-002, FS-EV-007, FS-EV-010, FS-EV-013

Known modeled gaps: No modeled finding; not assessed

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

PT-2 | Authority to Process Personally Identifiable Information

Assessment status: Illustrative; not assessed

Allocation: Shared: customer privacy/legal and mission authorities; tenant operator for approved handling; provider for service processing terms.

The notional privacy officer would determine legal authority, purpose, permitted recipients, and minimization before allowing operational personal information in tenant collaboration or audit exports. This fixture deliberately uses invented aliases and example.test contacts, with no actual personnel or sensitive records. Microsoft would provide applicable service processing terms and candidate safeguards but would not establish the customer's authority to collect or disclose mission data. Tenant operators would translate approved handling rules into available restrictions, subject to cloud and license verification. Customer data owners would review guest sharing and support drafts for unnecessary personal information. Missing authority or recipient approval would block the proposed processing, not be excused by the tenant's IL5 context.

Notional organization-defined parameters

Notional targets: authority/purpose review before new processing use; annual revalidation; sample 5 use cases including identity, audit export, guest sharing, records hold, and support escalation; no operational PII in fixture evidence.

Examine / interview / test

Examine authority and purpose documentation, privacy analyses, recipient conditions, and minimization rules. Interview privacy and mission owners. Test review of five invented data-use requests, including denial of an unsupported guest disclosure and redaction of a support draft.

Acceptance criterion

Every operational use has documented authority, compatible purpose, necessary data, and approved recipients; unsupported sharing is denied; fixture samples contain only invented non-sensitive data. Public IL5 documentation is not processing authority.

Evidence: FS-EV-008, FS-EV-013, FS-EV-015

Known modeled gaps: FS-FIND-002

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

RA-5 | Vulnerability Monitoring and Scanning

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for SaaS platform vulnerability management; tenant operator for configuration exposure review; external customer endpoint owner.

The notional security manager would combine authorized provider assurance, service advisories, tenant configuration exposure review, and separately owned endpoint findings into a responsibility-aware register. The tenant operator would not scan Microsoft infrastructure without explicit authorization or pretend that an IaaS scanner inventory represents Microsoft 365. Microsoft would retain candidate platform scanning and remediation duties, with current evidence required before inheritance. Customer endpoint and network authorities retain their own scanning obligations outside this boundary. Tenant review would focus on exposed sharing, excessive roles, unsupported integrations, and policy drift using verified interfaces. Optional Defender assessments require cloud and SKU verification. No live scan, provider vulnerability report, or actual exposure result is supplied.

Notional organization-defined parameters

Notional targets: review relevant advisories each business day; tenant exposure review monthly; critical tenant-owned issue triage within 1 business day; sample 10 settings and 3 provider advisories per review.

Examine / interview / test

Examine provider vulnerability assurance, tenant exposure reviews, and external endpoint responsibility mapping. Interview security manager and provider liaison. Test an inert excessive-permission configuration and advisory handoff, without scanning provider infrastructure or customer networks.

Acceptance criterion

Applicable provider assurance is current, all ten sampled settings receive documented review, and the synthetic critical exposure is assigned within one business day to the correct owner. Missing provider evidence prevents platform-inheritance credit.

Evidence: FS-EV-005, FS-EV-006, FS-EV-014

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SA-9 | External System Services

Assessment status: Illustrative; not assessed

Allocation: Shared: customer supplier assurance and system owner; provider for contracted service protections; tenant operator for retained duties.

The notional supplier assurance liaison would verify the exact Office 365 DoD services, authorization boundary, contractual responsibilities, support exclusions, and change-notification arrangements before proposing inheritance. GCC High documentation or a generic Microsoft compliance statement would not substitute for service-specific DoD applicability. Microsoft would supply authorized evidence of candidate service protections and customer responsibilities through appropriate channels. The tenant operator would retain configuration, identity, sharing, monitoring, and records duties, while customer mission authorities retain categorization and risk decisions. Support is outside the service accreditation boundary and requires separate handling review. The fixture includes only public-context references and missing-evidence requests, not a contract, authorization letter, registry verification, or actual supplier assessment.

Notional organization-defined parameters

Notional targets: verify all 4 collaboration workloads and tenant identity dependencies before inheritance; annual supplier review and material-change review; 100% retained duties assigned; support data release individually reviewed.

Examine / interview / test

Examine current authorized service scope, agreements, responsibility matrix, and support handling terms. Interview supplier liaison and system owner. Test desk-based tracing of each workload and a sanitized support case to applicable scope, retained duties, and approval authority.

Acceptance criterion

Every inherited claim has current service-specific authorized support, all retained duties have owners, and support exclusions are respected. Missing provider package or reliance solely on public pages fails inheritance readiness.

Evidence: FS-EV-005, FS-EV-014, FS-EV-015, FS-EV-016

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SC-7 | Boundary Protection

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for SaaS service boundaries; tenant operator for identity/sharing/access-policy interfaces; customer for external networks.

The notional tenant boundary would be enforced through approved identity trusts, workload permissions, sharing restrictions, and verified access-policy interfaces rather than a fictional tenant IaaS firewall. Microsoft would retain candidate infrastructure network and service-boundary protections, requiring current authorized evidence before inheritance. Customer networks and endpoint platforms remain outside this component inventory, with their responsibilities documented in interface agreements. The operator would restrict unapproved external recipients, applications, and support disclosures and would test denied paths using inert content. Logical tenant controls do not prove provider network isolation or prevent every external dependency risk. No network diagram, packet inspection result, provider boundary assessment, or live tenant policy test is supplied.

Notional organization-defined parameters

Notional targets: 10 documented flows; deny unapproved external paths; monthly review of identity/sharing/access interfaces; test 6 prohibited paths including anonymous sharing, stale posture, and unapproved federation.

Examine / interview / test

Examine service boundary evidence, flow approvals, and tenant policy settings. Interview identity, workload, and external network leads. Test six unauthorized logical paths in an isolated environment; verify separately that no provider network assurance is inferred from tenant tests.

Acceptance criterion

All six unauthorized tenant paths are denied, every allowed external flow is approved, and provider boundary inheritance has applicable evidence. Successful tenant denials alone cannot satisfy absent provider boundary protection evidence.

Evidence: FS-EV-005, FS-EV-006, FS-EV-015

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SC-8 | Transmission Confidentiality and Integrity

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for service transport mechanisms; tenant operator for configurable exchange policies; customer recipient/network authorities.

The notional operator would identify encryption and integrity requirements for interactive sessions, mail exchange, workload integration, audit export, and support coordination. Each path would be evaluated independently because authenticated web access does not establish equivalent protection for every mail recipient or external repository. Microsoft would provide candidate service transport mechanisms and applicable cryptographic evidence; the operator would configure supported restrictions and verify observed behavior. External customer network and recipient authorities retain their own transport responsibilities. No blanket end-to-end encryption claim is made for Teams, email, or stored collaboration content. Public IL5 scope does not prove protocol settings or approved modules. The provider cryptographic evidence needed for these claims is absent.

Notional organization-defined parameters

Notional targets: approved encrypted transport for every external flow; TLS 1.2 or later where the customer can verify and configure it; no plaintext fallback for exchanges requiring encryption; sample all external flow classes.

Examine / interview / test

Examine documented transport requirements, supported settings, and provider cryptographic scope. Interview workload and external exchange owners. Test approved session/mail/export paths and one prohibited downgrade or unencrypted exchange where safe and supported, using only inert content.

Acceptance criterion

Every sampled path meets its approved confidentiality/integrity requirement and rejects prohibited fallback; provider cryptographic applicability is evidenced. Unobservable or unsupported paths remain unresolved rather than being credited from marketing documentation.

Evidence: FS-EV-005, FS-EV-006, FS-EV-015

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SC-13 | Cryptographic Protection

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for service cryptographic mechanisms; tenant operator for supported configuration; customer security authority for required protection.

The notional security manager would record cryptographic requirements by information type and path, then request evidence connecting applicable service mechanisms to those requirements. Microsoft would be the candidate owner of underlying service cryptography and key management, while the tenant operator controls only supported customer settings. This inventory does not invent an Azure Key Vault or assert customer-managed keys, double encryption, or a specific validated module. Optional encryption products require cloud, SKU, licensing, and authorized-boundary verification before consideration. Customer security authorities determine required algorithms and validation conditions. Public IL5 documentation is not module validation evidence. Without an applicable provider cryptographic package, the scenario deliberately leaves inheritance unresolved and records a high-severity fictional evidence gap.

Notional organization-defined parameters

Notional targets: cryptographic applicability matrix for identity plus all 4 collaboration workloads; current approved algorithm/module requirements determined by customer authority; annual evidence review and review upon material service change.

Examine / interview / test

Examine cryptographic requirements, provider mechanism/module applicability, and any tenant-selectable settings. Interview security manager and supplier liaison. Test desk-based traceability for five service areas and verify one safe customer-configurable encryption-related setting if available.

Acceptance criterion

Each required cryptographic protection maps to current applicable evidence and approved requirements, with clear provider/customer duties. Missing module applicability, unverified key-management claims, or unavailable product assumptions fail inheritance readiness.

Evidence: FS-EV-005, FS-EV-006, FS-EV-016

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SC-28 | Protection of Information at Rest

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for candidate service storage protection; tenant operator for permissions and handling; customer for exported/endpoint copies.

The notional operator would protect tenant-held content through approved permissions, recipient restrictions, records handling, and verified service storage safeguards. Microsoft would supply candidate at-rest cryptographic and storage isolation evidence for each actual DoD workload; tenant administrators would not infer that evidence from a label or IL5 landing page. Customer endpoint copies, downloaded files, and external evidence repositories remain outside this tenant boundary with separately assigned protection duties. Optional sensitivity-label or customer-key mechanisms are conditional on cloud and SKU verification and are not assumed. The operator would inventory where exercise content and derived exports reside and test access restrictions. No real storage configuration, key evidence, or authorized provider assurance package is supplied.

Notional organization-defined parameters

Notional targets: map at-rest protection for Exchange, SharePoint, OneDrive, Teams-associated storage, and tenant audit records; review monthly access samples and annually provider evidence; prohibit unapproved export destinations.

Examine / interview / test

Examine service storage/cryptographic evidence, content-location mapping, and external-copy handling. Interview workload and privacy owners. Test authorized and unauthorized retrieval of inert stored objects and an export to an unapproved destination.

Acceptance criterion

Each storage location has applicable protection evidence and assigned responsibility; unauthorized retrieval/export is denied; external copies have separately approved handling. Tenant permission tests do not cure absent service storage evidence.

Evidence: FS-EV-005, FS-EV-006, FS-EV-009, FS-EV-015

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

SI-2 | Flaw Remediation

Assessment status: Illustrative; not assessed

Allocation: Shared: provider for SaaS platform flaws; tenant operator for configurable-policy defects; customer endpoint/network owners for external flaws.

The notional security manager would triage advisories and defects into provider platform issues, tenant configuration issues, and external customer endpoint or network issues. Microsoft would retain candidate SaaS patching responsibilities and supply applicable assurance or incident updates; the tenant operator would not fabricate VM patch inventories or claim direct control of provider releases. Tenant-owned policy defects would enter the change process with risk priority, testing, rollback, and independent verification. External computing authorities would receive endpoint findings through a documented handoff. Optional Defender or security-posture tooling is not presumed available. No real vulnerability, provider patch status, or remediation completion is asserted; missing provider evidence remains an explicit fictional gap.

Notional organization-defined parameters

Notional targets: critical tenant-owned defect triage within 1 business day and correction target 7 days; high target 14 days; moderate target 30 days; approved risk decisions required for extensions; provider timing verified separately.

Examine / interview / test

Examine defect queues, provider advisories, change approvals, and external handoff records. Interview security manager, change chair, and endpoint liaison. Test routing and correction of one inert tenant policy defect plus one provider and one external endpoint advisory scenario.

Acceptance criterion

Each scenario reaches the correct owner, tenant correction meets its approved deadline and negative retest, and provider remediation claims have applicable evidence. Tenant-owned fixes cannot establish SaaS platform patch compliance.

Evidence: FS-EV-003, FS-EV-005, FS-EV-006, FS-EV-014

Known modeled gaps: FS-FIND-005

Acceptance criteria are future assessment conditions, not recorded test results. Refer to the evidence register before claiming inheritance.

SYNTHETIC TEST DATA - NOT A VALID ATO

6. Limitations and public reference basis

- Original synthetic test scenario only. Flank Speed-inspired naming is contextual and does not reproduce or verify the Navy's actual configuration, operational boundary, assessment, or ATO.
- The parent verified the four public reference pages listed below on 2026-09-24. This authoring task made no network requests and did not independently re-fetch those pages.
- The Navy public Flank Speed page could not be retrieved by the parent; no Navy-specific configuration or current authorization status was verified.
- Office 365 DoD is not interchangeable with GCC High. Public service inclusion and IL5 context do not establish the fictional tenant's authorization or inheritance.
- Every inventory entry, target, role, organization, count, event, timestamp, observation, and remediation schedule is notional. No actual assessment procedures, tenant commands, scanning, support requests, or restoration actions were performed.
- No control is claimed implemented, effective, certified, or satisfied. All forty controls are illustrative and not assessed; provider duties are candidates awaiting applicable evidence.
- Only four meaningful invented samples are included; the remaining twelve evidence entries are Not supplied with empty sampleText. None of the sixteen entries is accepted operational evidence.
- All six findings are fictional and Open: two High, three Moderate, one Low. They describe this scenario's review/evidence gaps, not actual vulnerabilities or defects in Navy or Microsoft systems.
- All six matching POAMs have future milestones and empty closureEvidence arrays. No corrective action has been submitted, accepted, or closed.
- The control set is representative, not a complete IL5, FedRAMP High, CNSSI 1253, NIST enhancement, or organization-tailored baseline. Actual control selection and parameters require authority review.
- Cloud, SKU, license, feature behavior, and authorized-boundary availability must be verified for any Purview, Defender, advanced audit, retention/hold, information protection, conditional-access, privileged-management, or other optional mechanism.
- Endpoints, endpoint-management platforms, customer networks, external federation infrastructure, recipient systems, external SIEM/evidence storage, third-party backup, arbitrary Azure resources, and support handling remain outside the modeled tenant boundary.
- No Azure Key Vault, IaaS firewall, VM inventory, AI/Copilot service, unapproved application, real person, real government identifier, credential, signature, seal, classified information, or operational CUI is included.
- Retention, version history, recycle bins, and holds have purpose-specific limits and do not guarantee complete backup, recovery, or preservation of every workload object, permission, or dependency.
- Contacts are nonoperational example.test addresses. Notional reporting times are not asserted as actual DoD regulatory deadlines or contractual service guarantees.
- Evidence cross-references identify planned relevance and requested artifacts, not proof that an artifact exists or satisfies a control. Missing provider evidence is not proof that the provider lacks the underlying protection.
- The decision is an unsigned illustrative conditional ATO draft, not effective. Importing, rendering, publishing a fixture, or reaching a proposed date cannot activate it.
- This JSON is a document-content fixture, not OSCAL, an official eMASS/FedRAMP submission template, a source of legal advice, or an application test-result report. Parent generation and manual application validation remain separate.

SYNTHETIC TEST DATA - NOT A VALID ATO

FS-REF-001 | Microsoft Office 365 GCC High and DoD service description

<https://learn.microsoft.com/en-us/office365/servicedescriptions/office-365-platform-service-description/office-365-us-government/gcc-high-and-dod>

Read on: 2026-09-24

Parent-read public context: Office 365 DoD is exclusive to DoD and designed for IL5; GCC High is distinct; support service is outside the service accreditation boundary. Does not establish this fixture's tenant configuration, authorization, or inherited-control evidence.

Public background only; not tenant authorization evidence.

FS-REF-002 | Microsoft DoD IL5 compliance offering overview

<https://learn.microsoft.com/en-us/compliance/regulatory/offering-dod-il5>

Read on: 2026-09-24

Parent-read public context identifying Exchange Online, SharePoint, OneDrive, and Teams within the DoD service offering scope described on that page. Not proof of actual tenant provisioning, authorization, optional feature availability, or successful assessment.

Public background only; not tenant authorization evidence.

FS-REF-003 | NIST SP 800-37 Rev. 2: Risk Management Framework for Information Systems and Organizations

<https://csrc.nist.gov/pubs/sp/800/37/r2/final>

Read on: 2026-09-24

Parent-read methodology context for responsibility allocation, assessment, authorization decisions, and monitoring. Does not authorize the synthetic tenant or approve its categorization, control subset, or proposed decision.

Public background only; not tenant authorization evidence.

FS-REF-004 | NIST SP 800-53A Rev. 5: Assessing Security and Privacy Controls in Information Systems and Organizations

<https://csrc.nist.gov/pubs/sp/800/53/a/r5/final>

Read on: 2026-09-24

Parent-read methodology context for examine/interview/test procedures and evidence-based assessment. The publication page notes an update; this fixture uses representative Rev. 5 control identifiers, not a complete release-specific assessment procedure set or actual assessment results.

Public background only; not tenant authorization evidence.